The PACS-man Comes For Us All

We May Be Vaccinated, but Physical Access Control Still Sucks

Babak Javadi (Omikron)

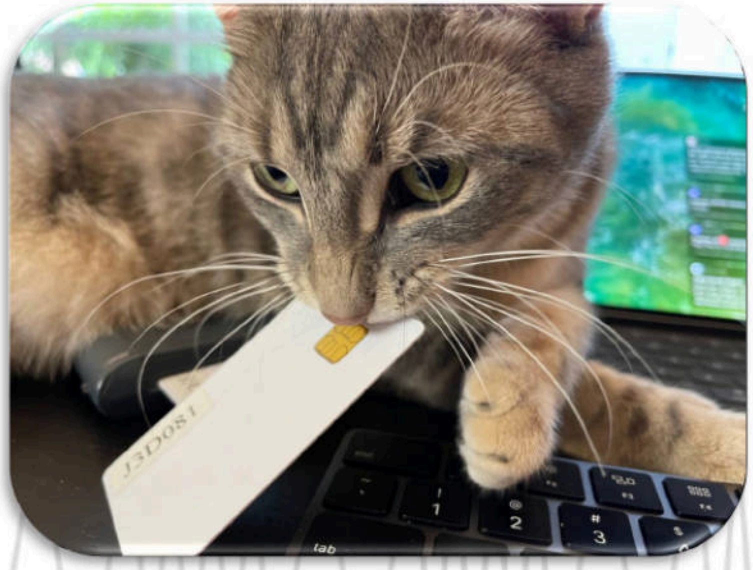
Co-Founder, Red Team Alliance

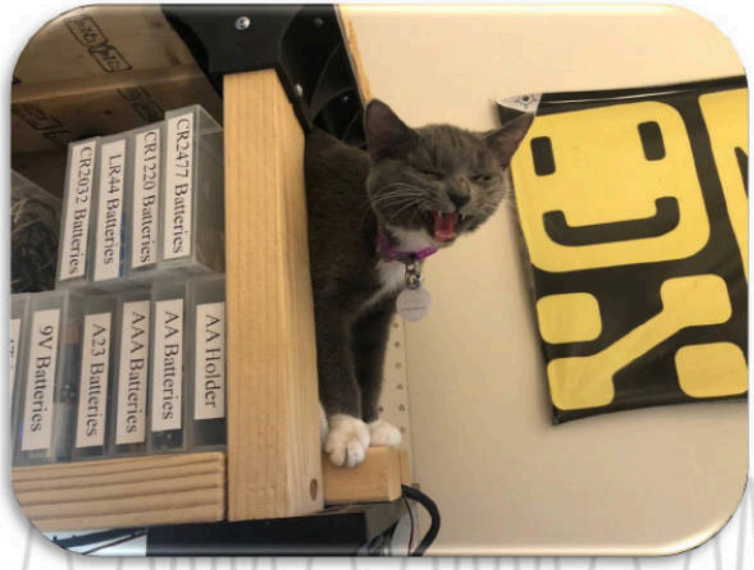
- Lockpicker
- Hardware Hacker
- Professional Red Teamer and Covert Entry Instructor
- Red Team Alliance, Co-Founder
  - Physical Security Training and Certification
- TOOOL, Co-Founder
  - 501(c)(3) Non-Profit Educational Lockpicking Organization
- Founder and Director of Research of The CORE Group
  - Penetration Testing / Reverse Engineering

@babakjavadi

Nick Draffen (tcprst)

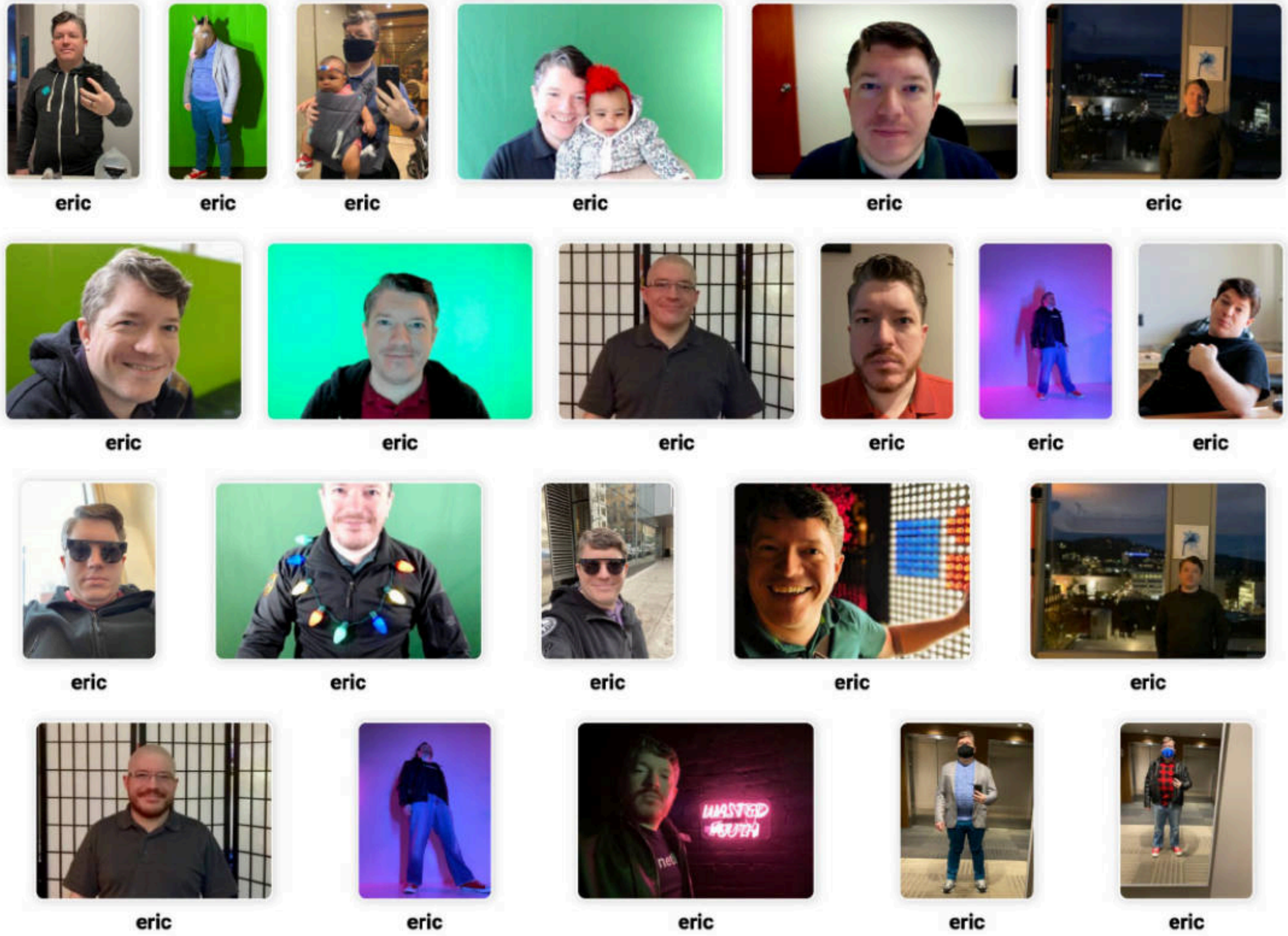
- Hacks things where Physical/Digital Intersect
- RFID Hacking by Iceman Discord Moderator 
- Likes to wear T-shirts
- Cat dad





@tcprst

Eric Betts (bettse)



@aguynamedbettse

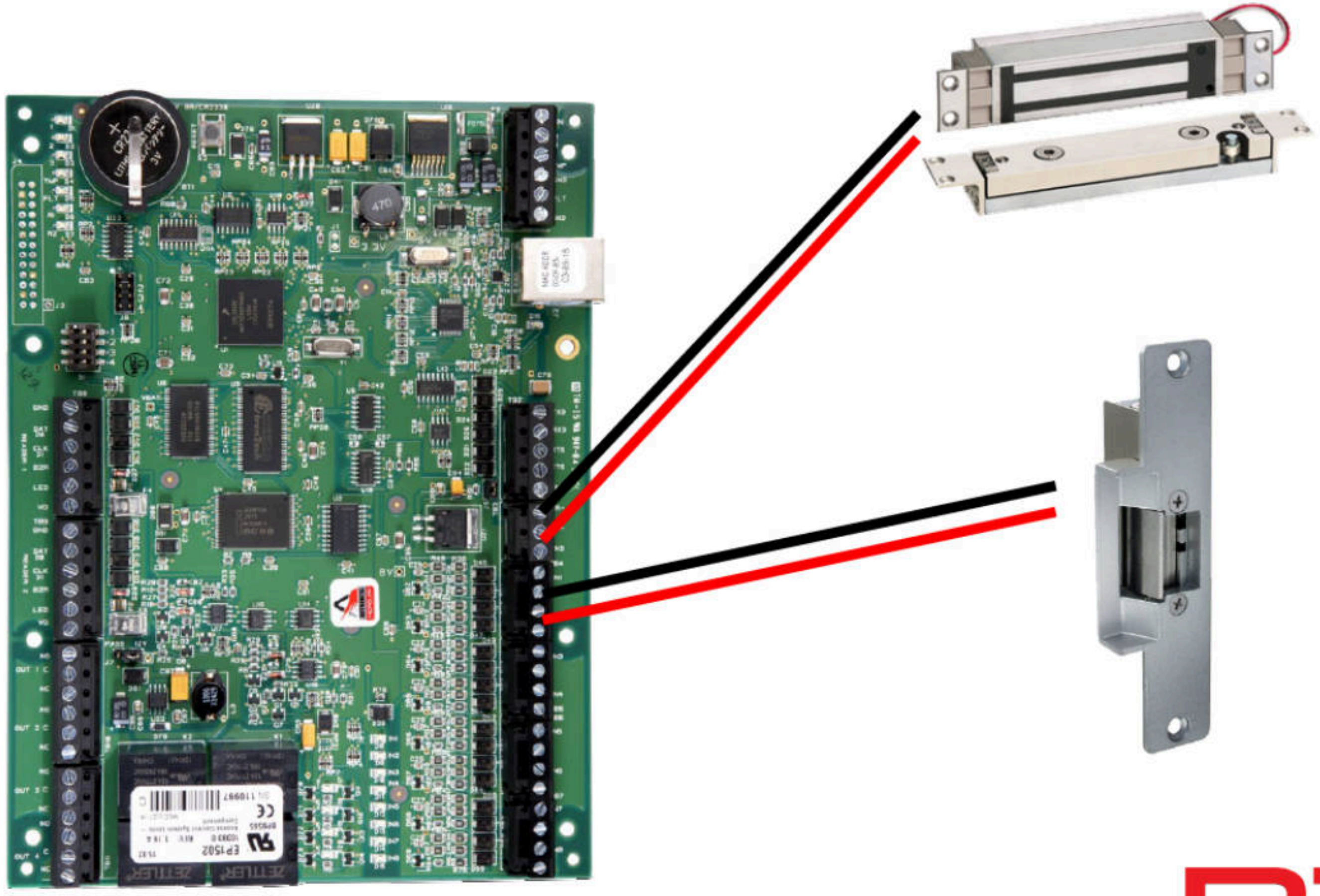
Anže Jenšterle (craftbyte)

- Student of Computer Science
- Security Researcher
- Hardware Disassembler
- Bug Bounty Hunter
- Member of Google VRP Hall of Fame

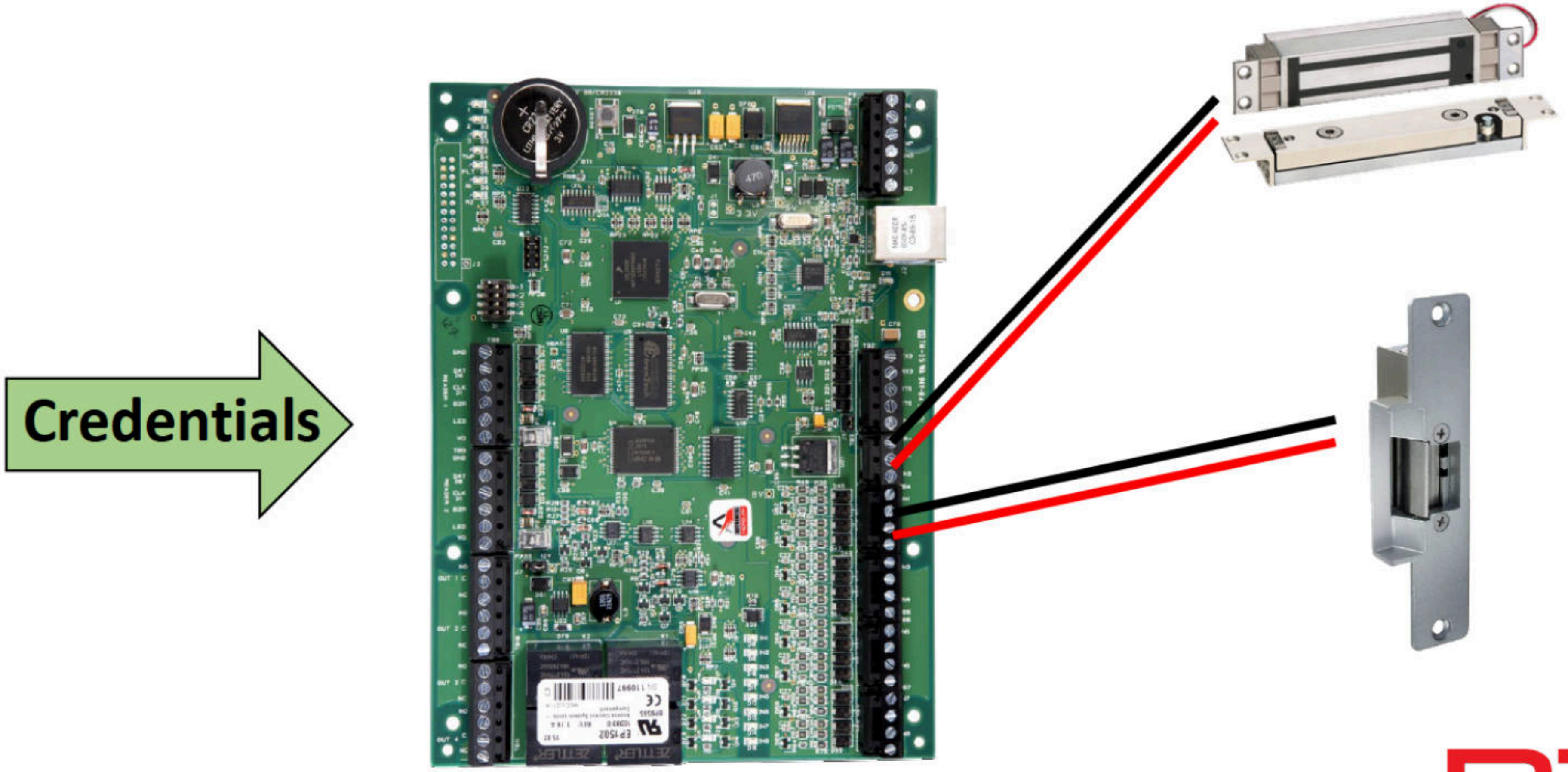
@applejacksec

What is the PACS-Man?

Access Control System Basics



Access Control System Basics



Think of RFID Credentials as a Container

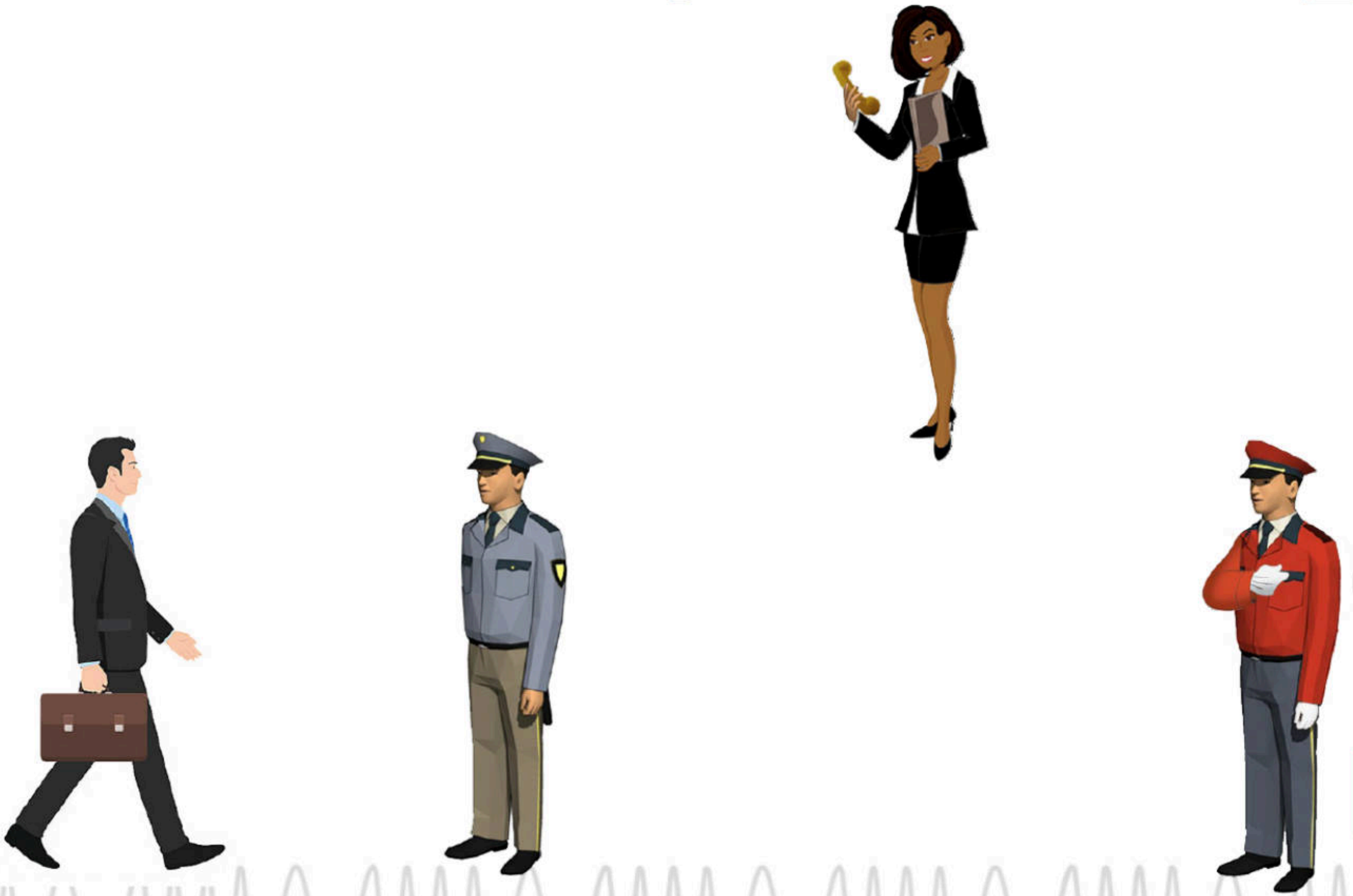
Many Credentials are Simply Like Folders

Many Credentials are Simply Like Folders

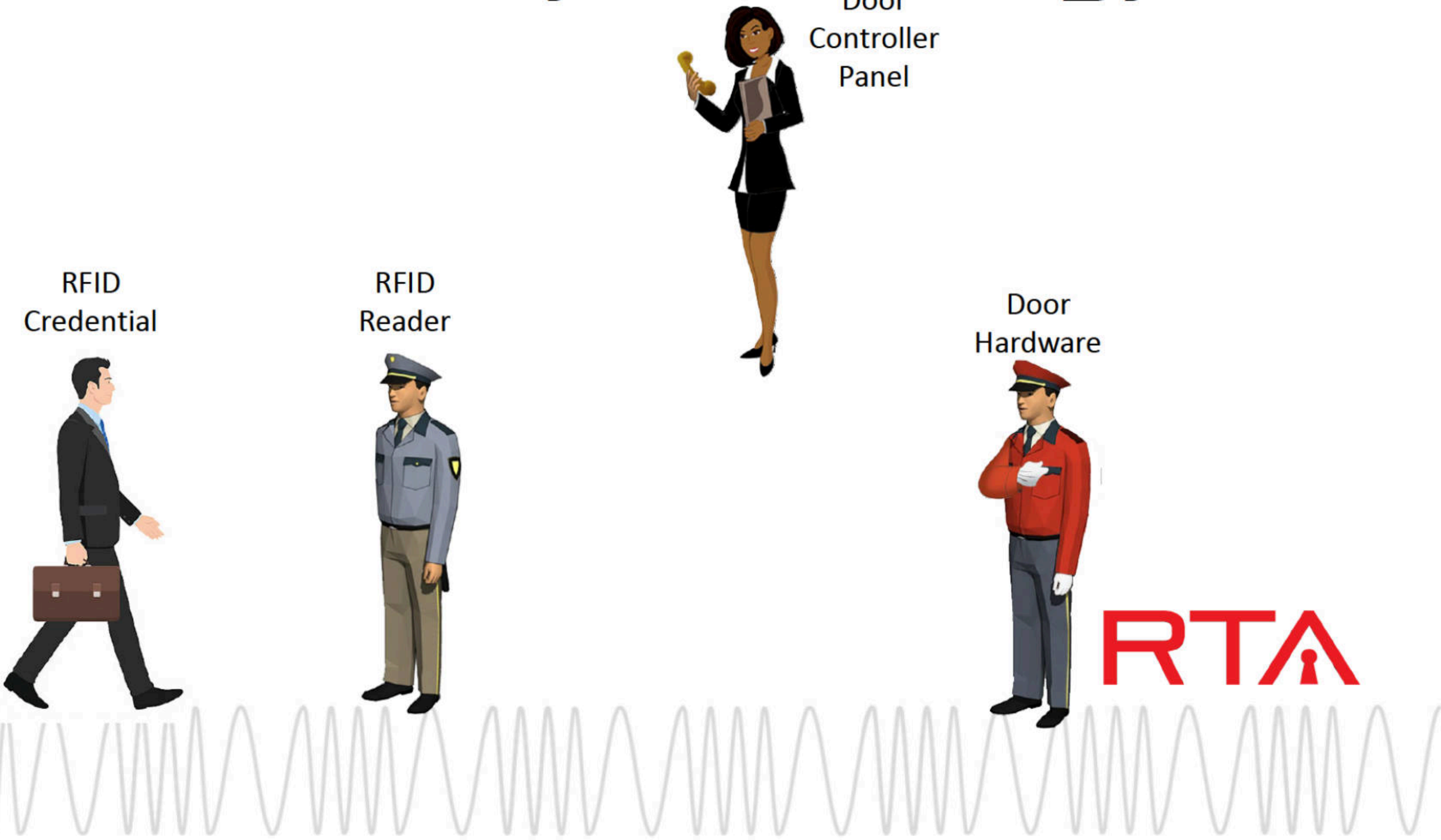
RTA

Many Credentials are Simply Like Folders

Access Control System Analogy



Access Control System Analogy



Access Control System Analogy

Door
Controller
Panel

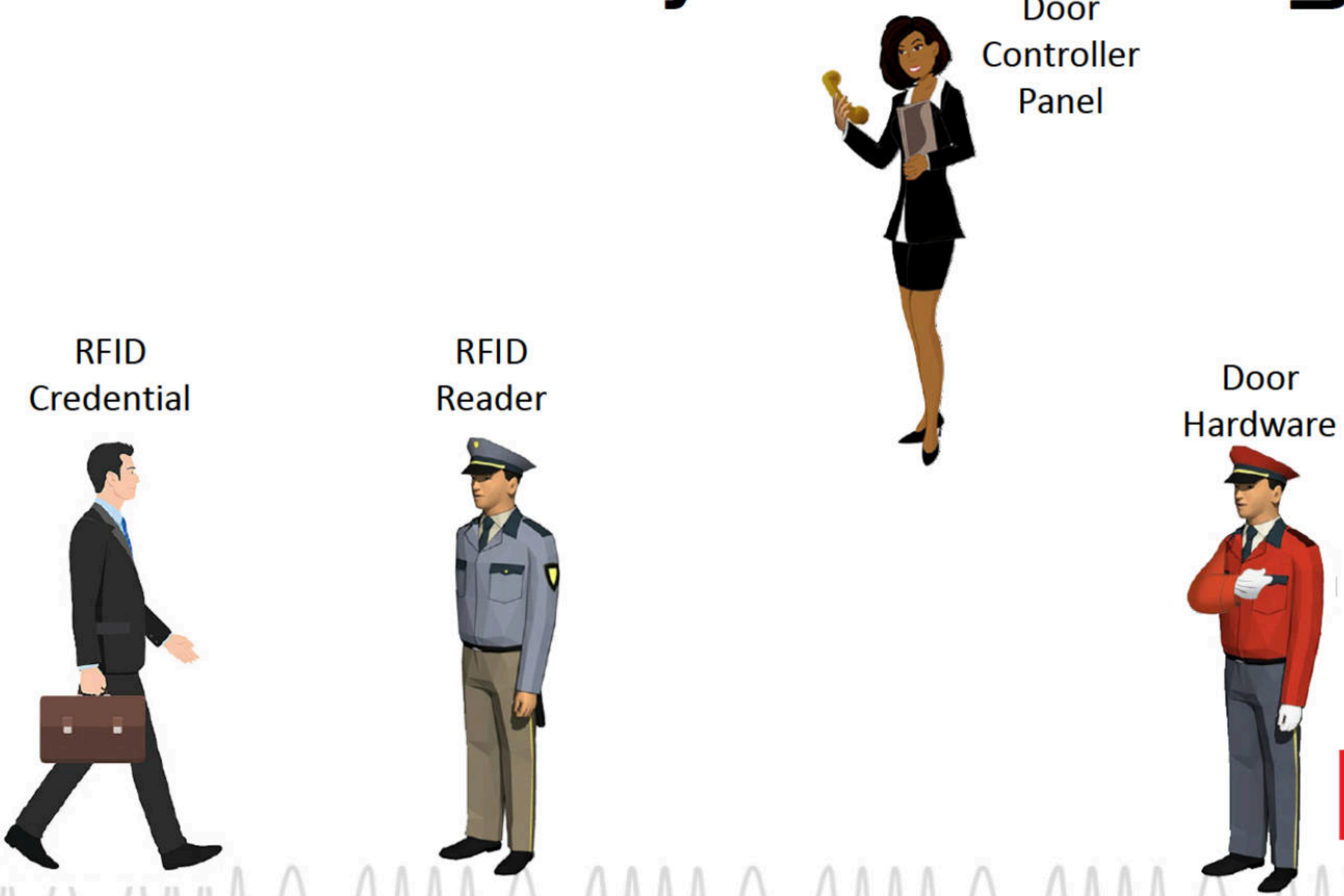
RFID
Credential

RFID
Reader

Door
Hardware

RTA

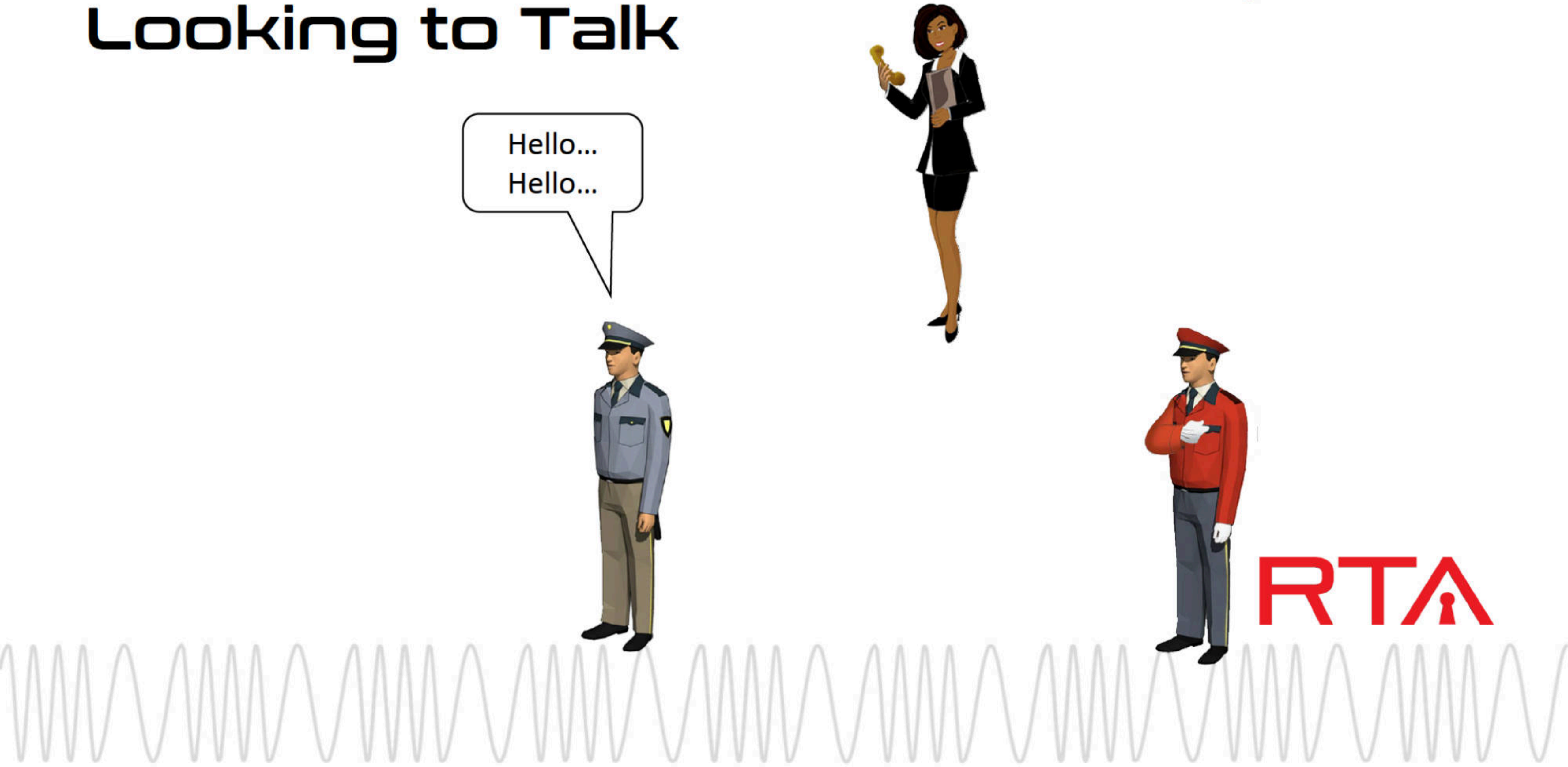
Access Control System Analogy



Access Control System Analogy

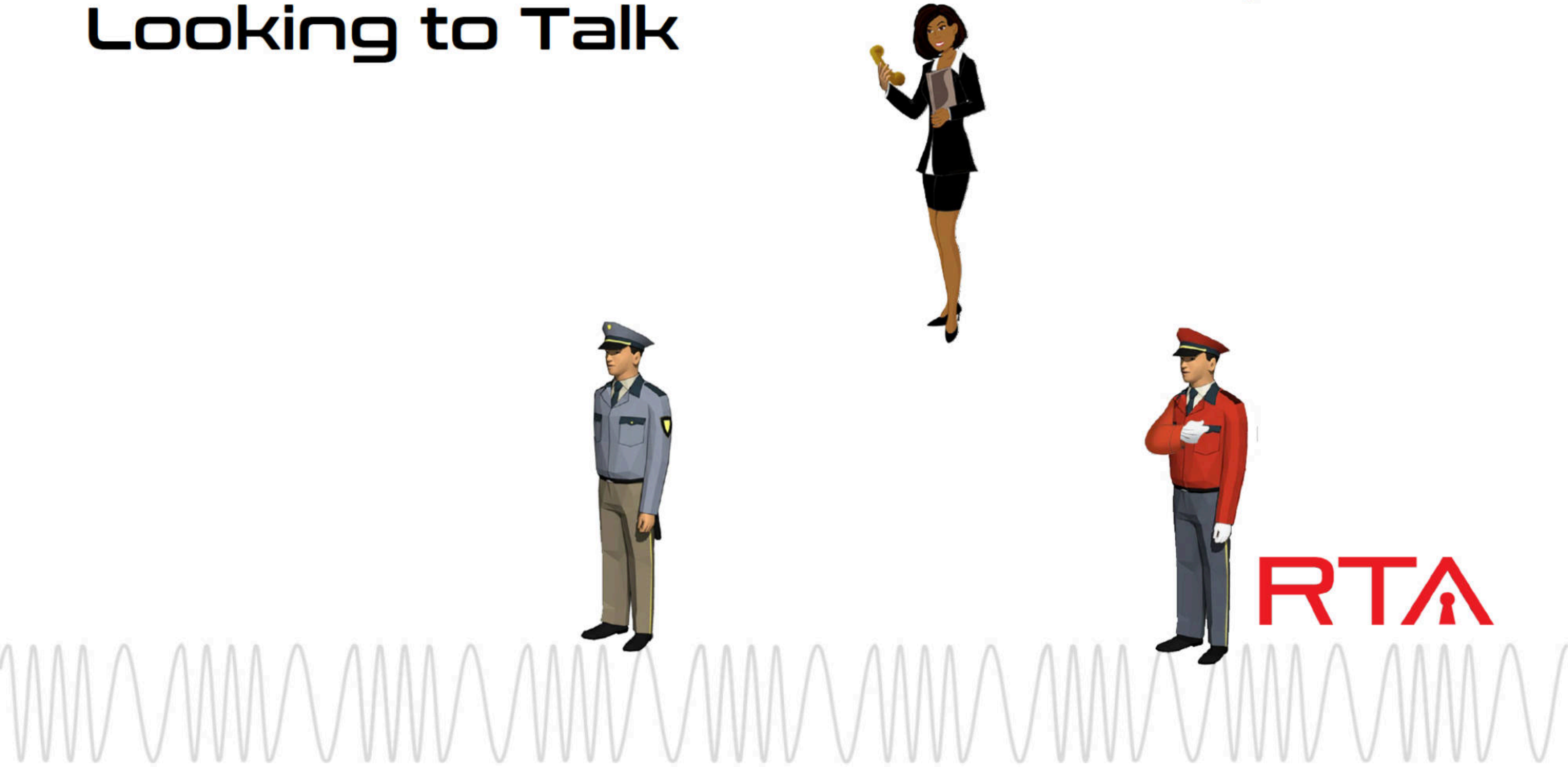
The Credential Reader is Always Looking to Talk

The Credential Reader is Always Looking to Talk

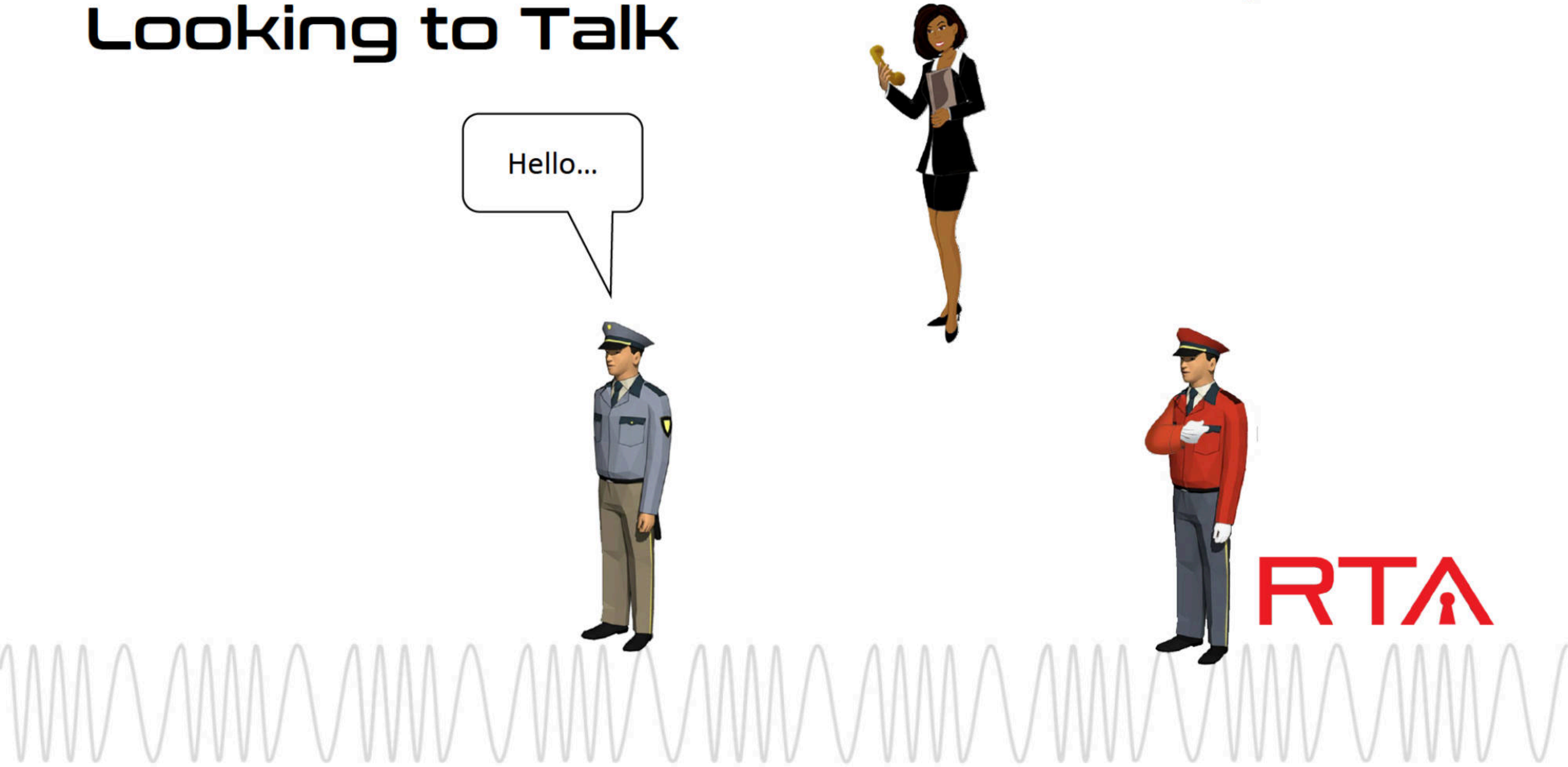


RTA

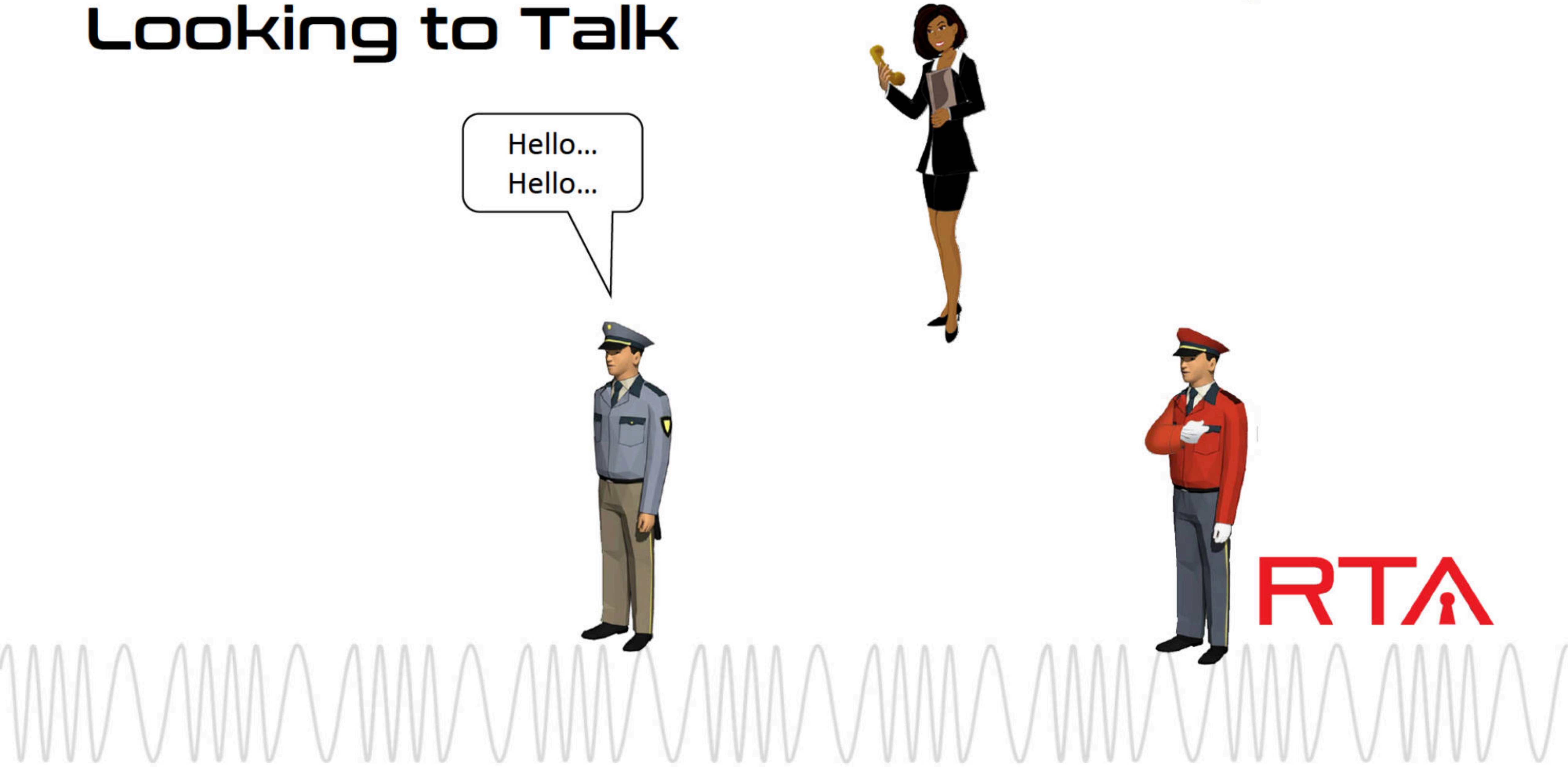
The Credential Reader is Always Looking to Talk



The Credential Reader is Always Looking to Talk



The Credential Reader is Always Looking to Talk



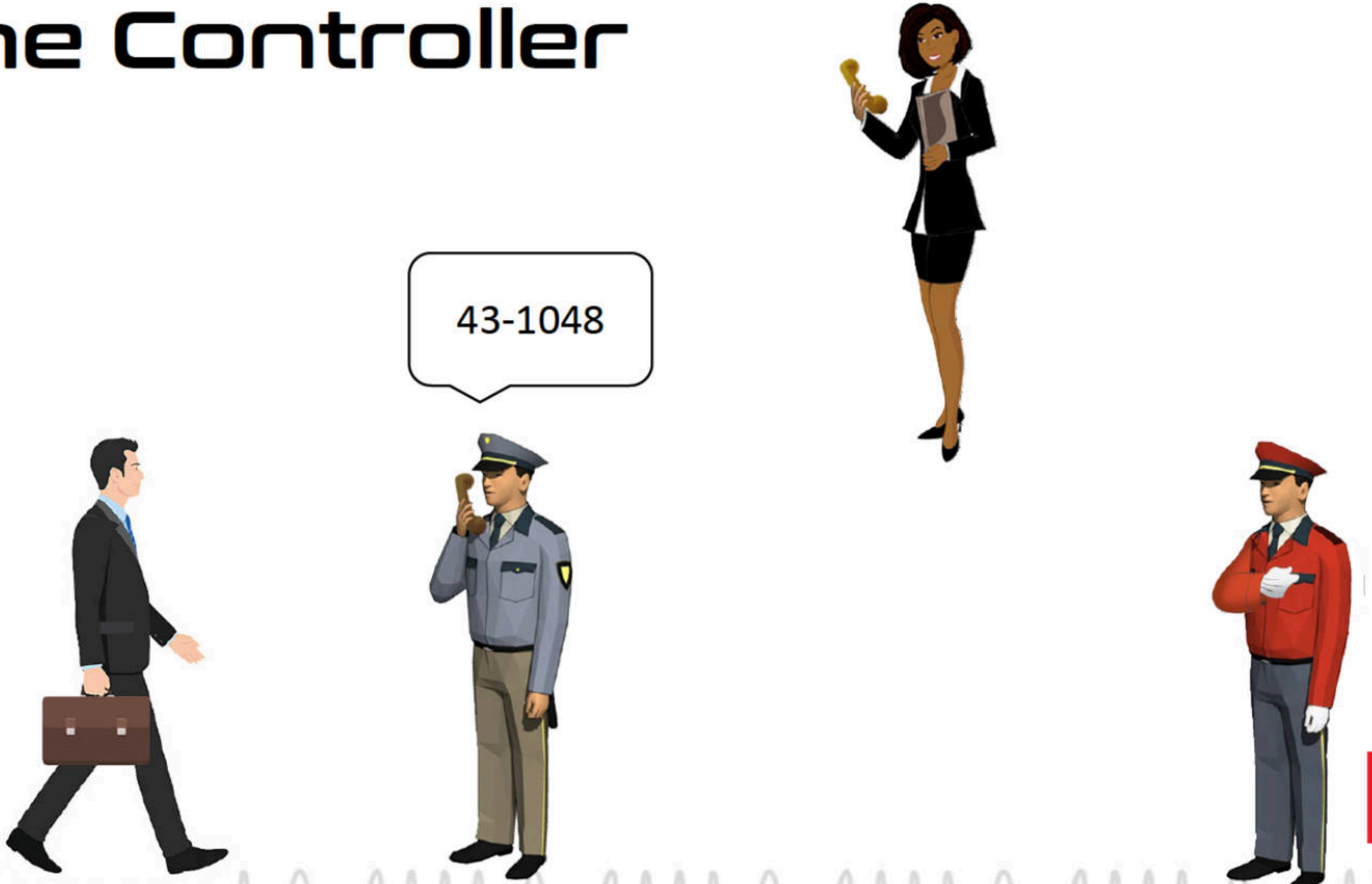
The Credential Reader is Always Looking to Talk

The Credential Reader is Always Looking to Talk

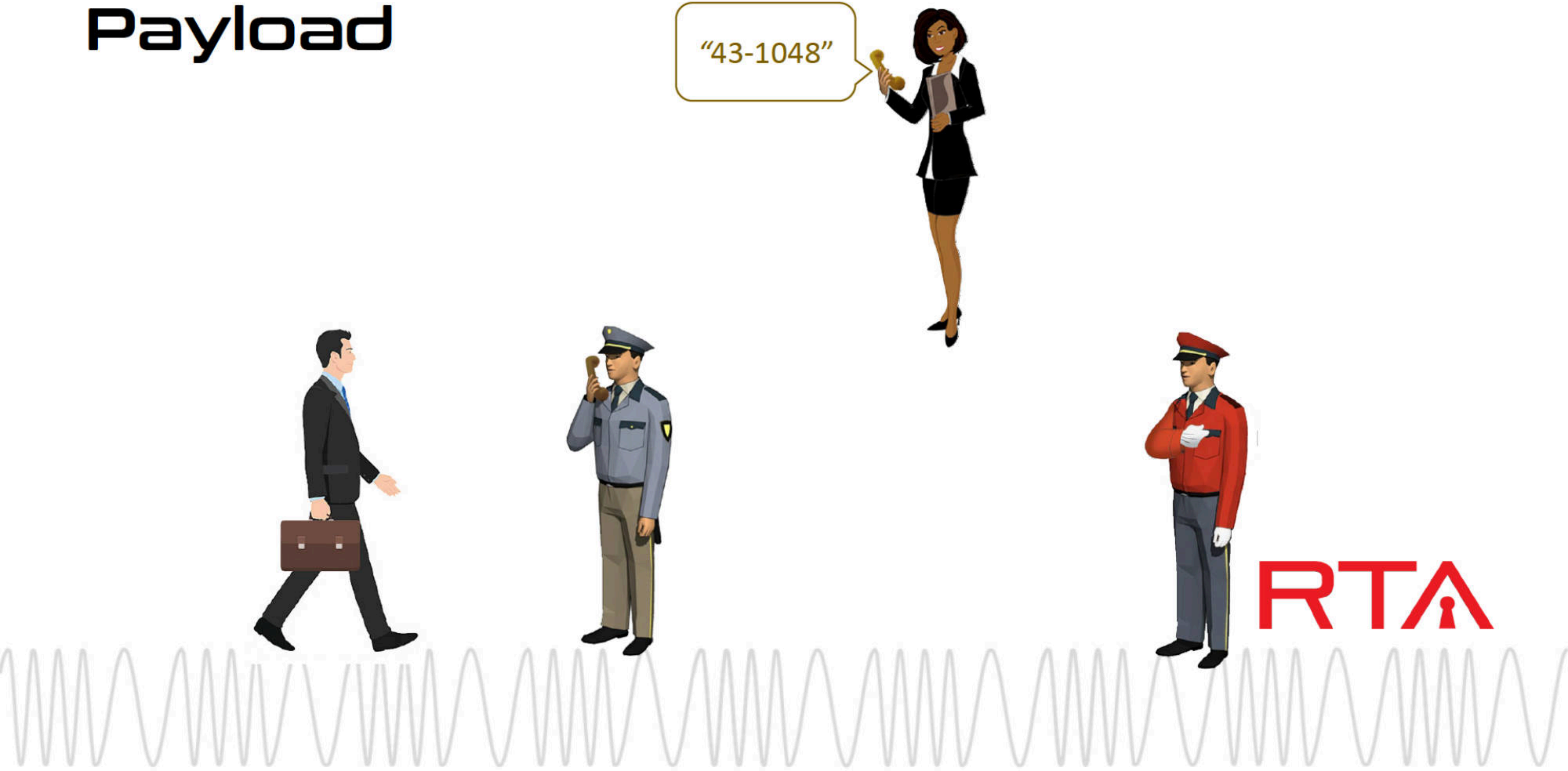
Along Comes a Credential

This Credential Responds Very Directly and Simply

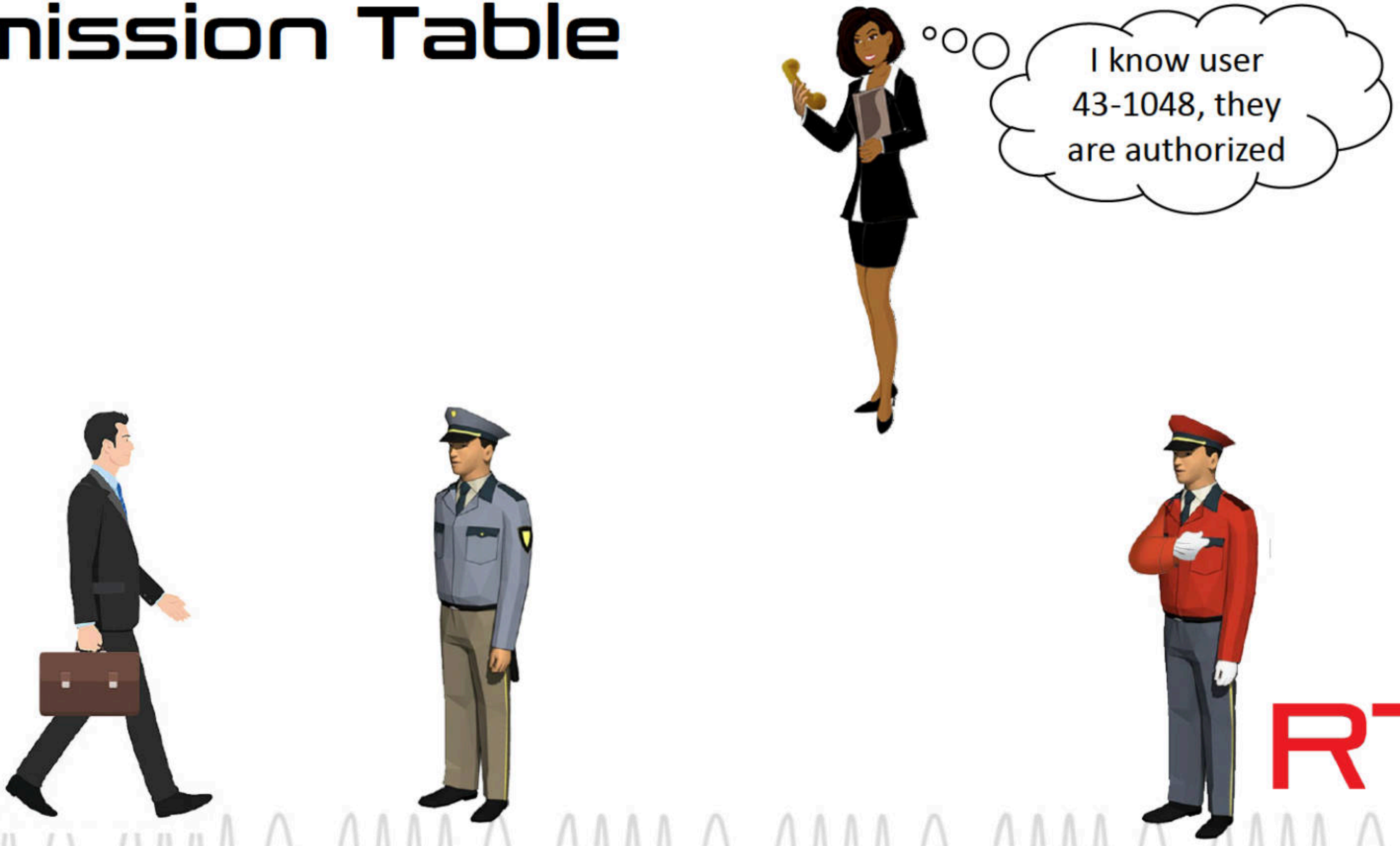
Reader Transmits the PACS Payload to the Controller



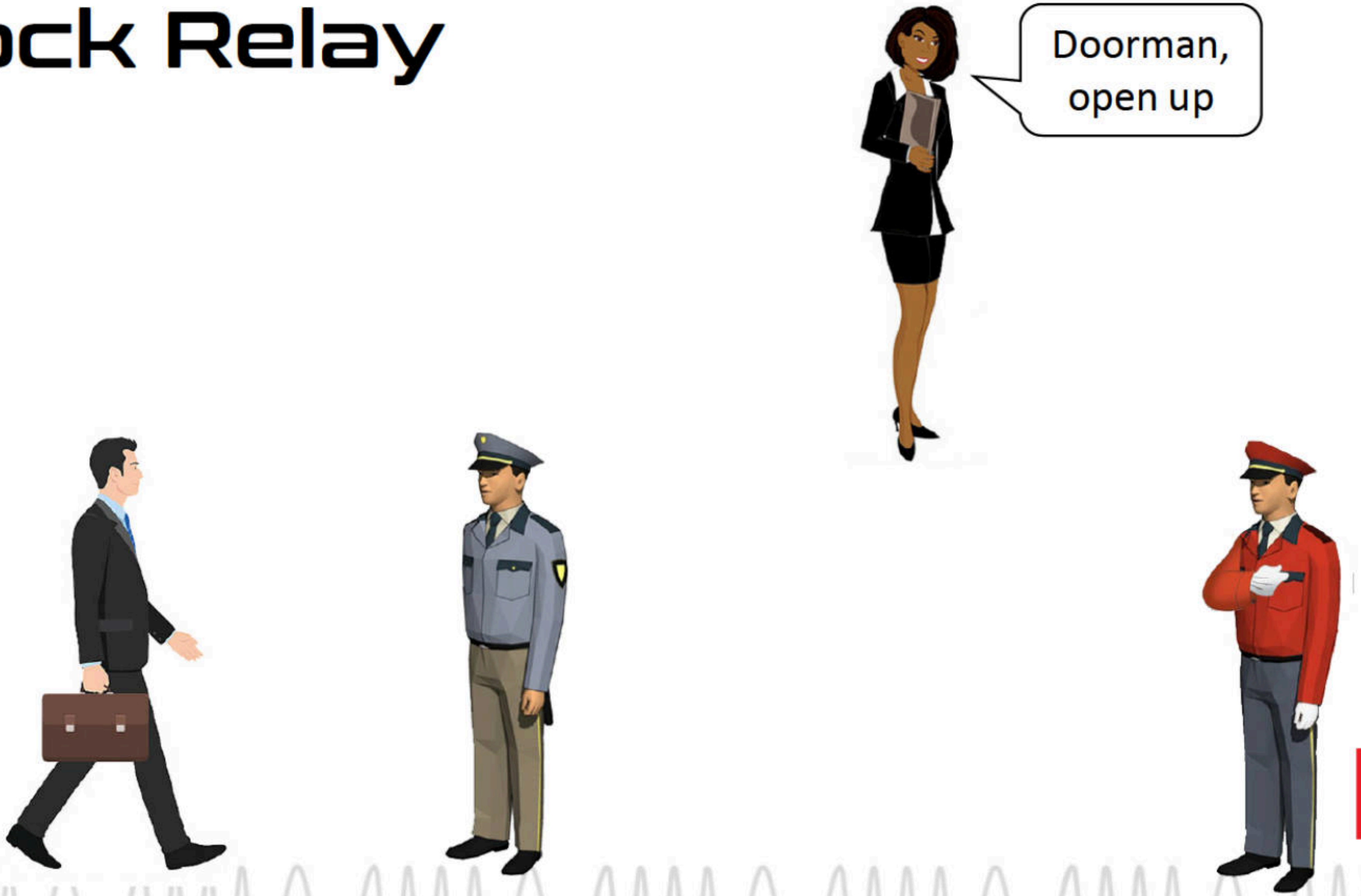
The Controller Receives the PACS Payload



The Controller Checks Their User Permission Table



The Controller Activates the Door Unlock Relay



RTA

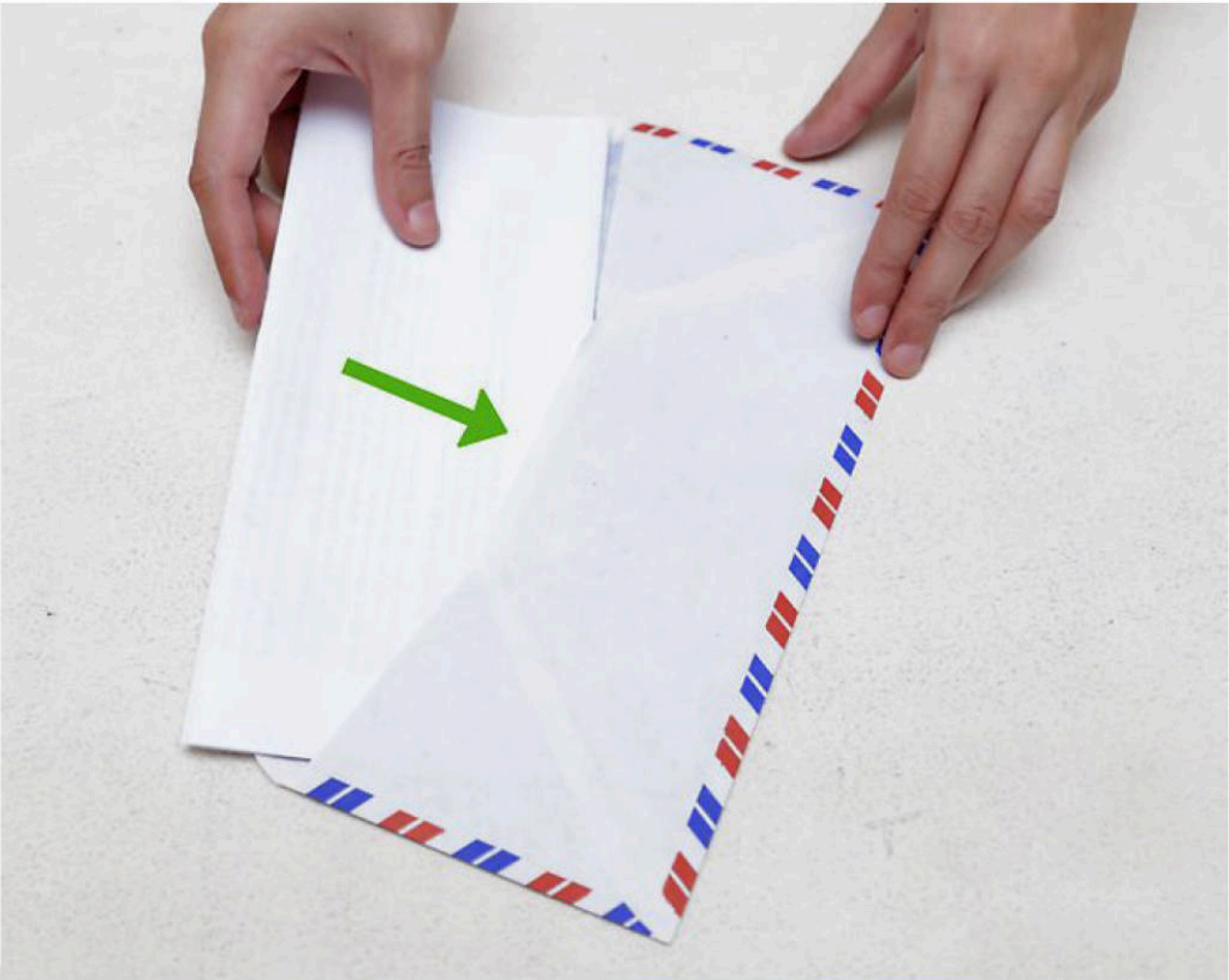
Access is Granted

Some Credentials Must Be "Unlocked"

Credential Analogy

Credential Analogy

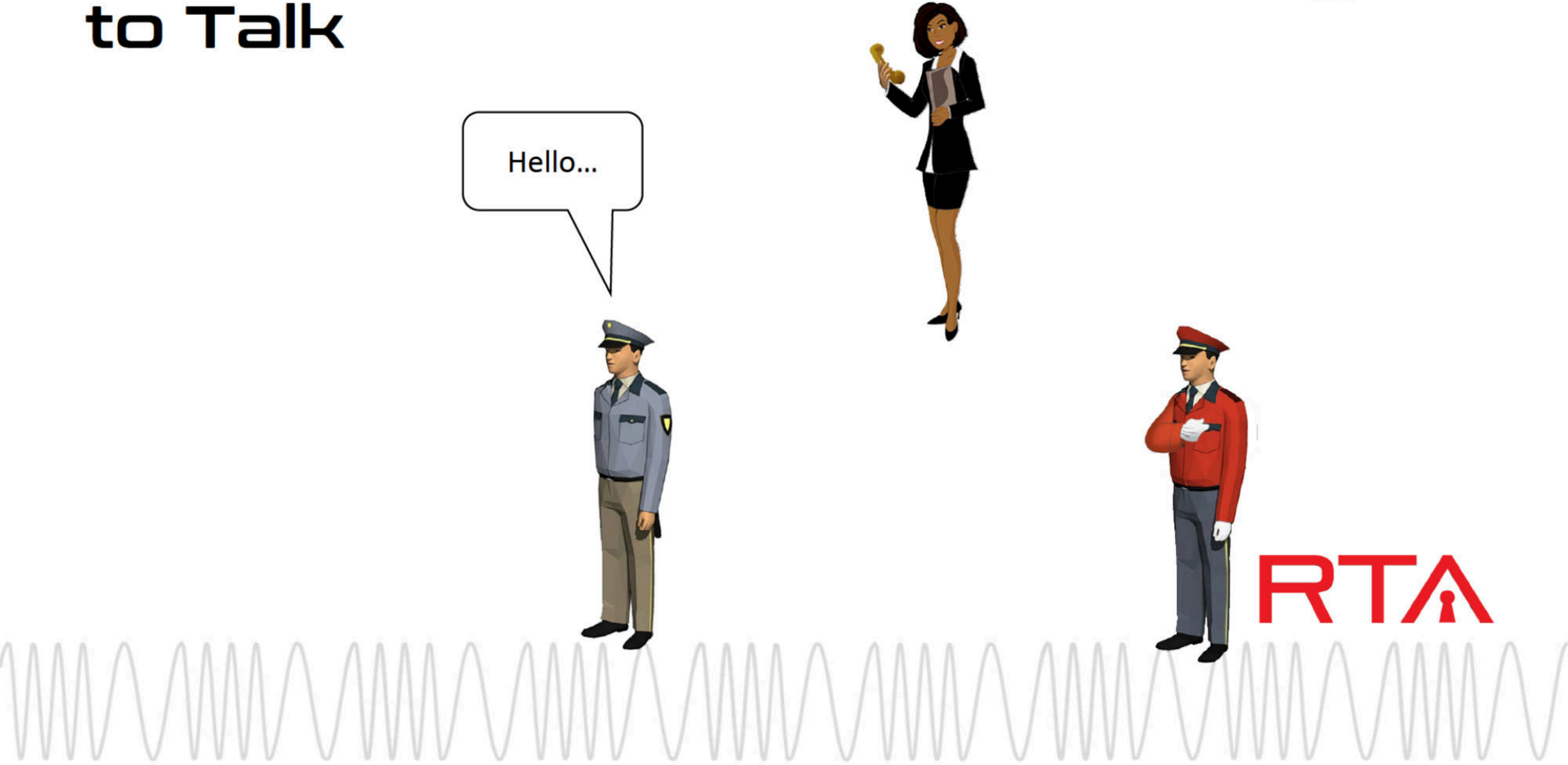
Credential Analogy



Credential Analogy

Credential Analogy

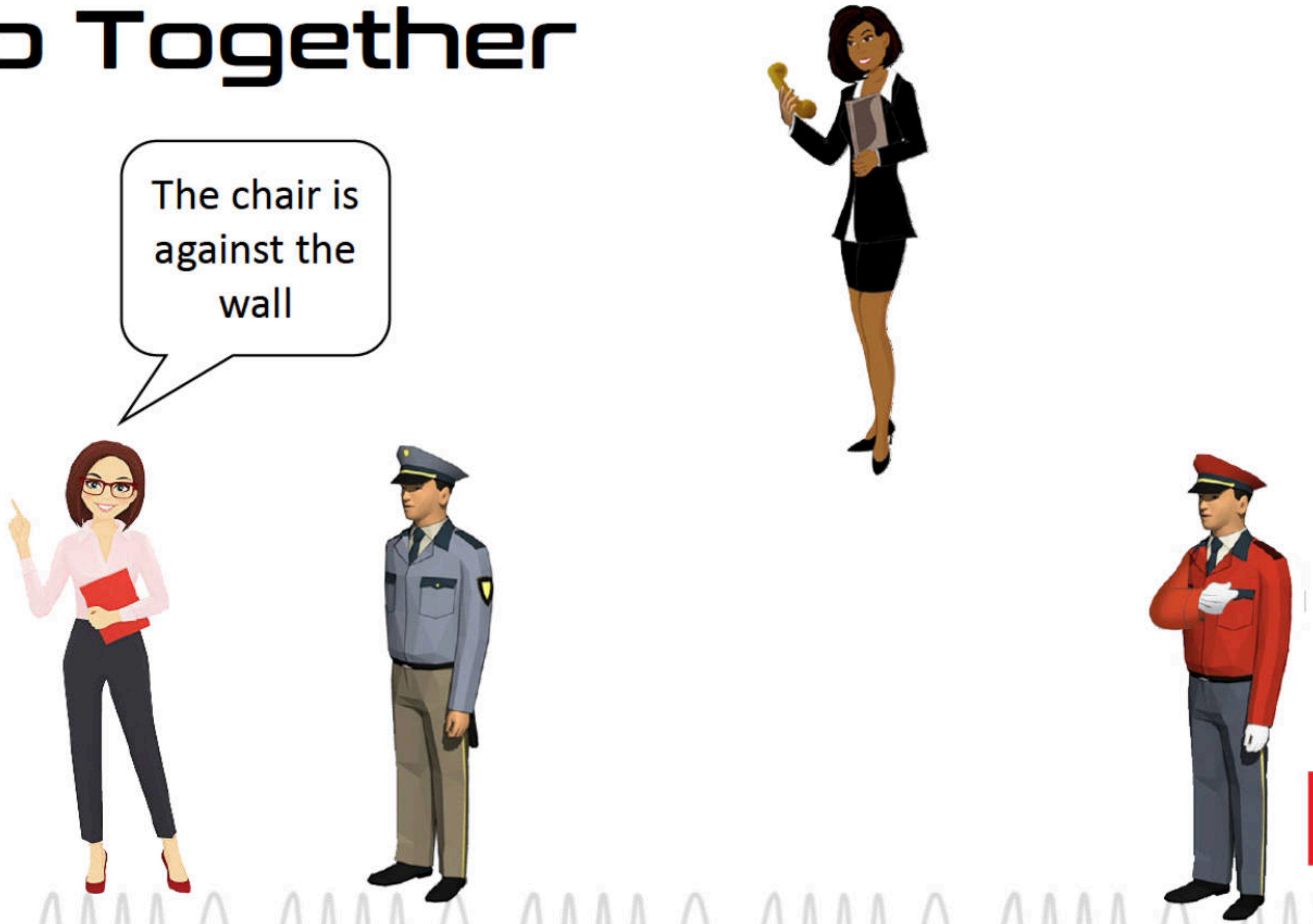
The Credential Reader is Looking to Talk



Let's See How This Credential Interacts

This Credential Is Tight-Lipped with its Payload

The Credential and the Reader Do Crypto Together

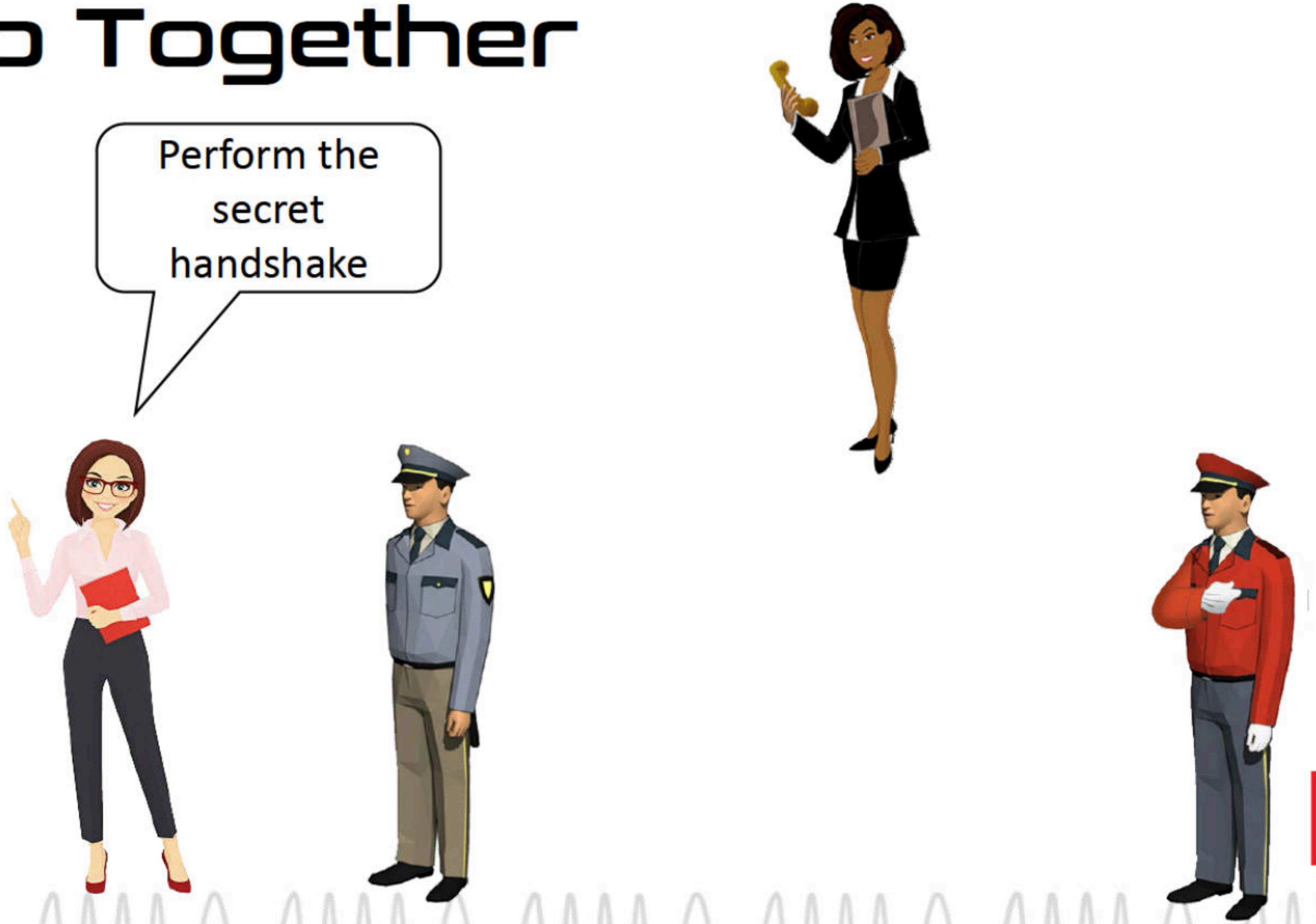


RTA

The Credential and the Reader Do Crypto Together

RTA

The Credential and the Reader Do Crypto Together



RTA

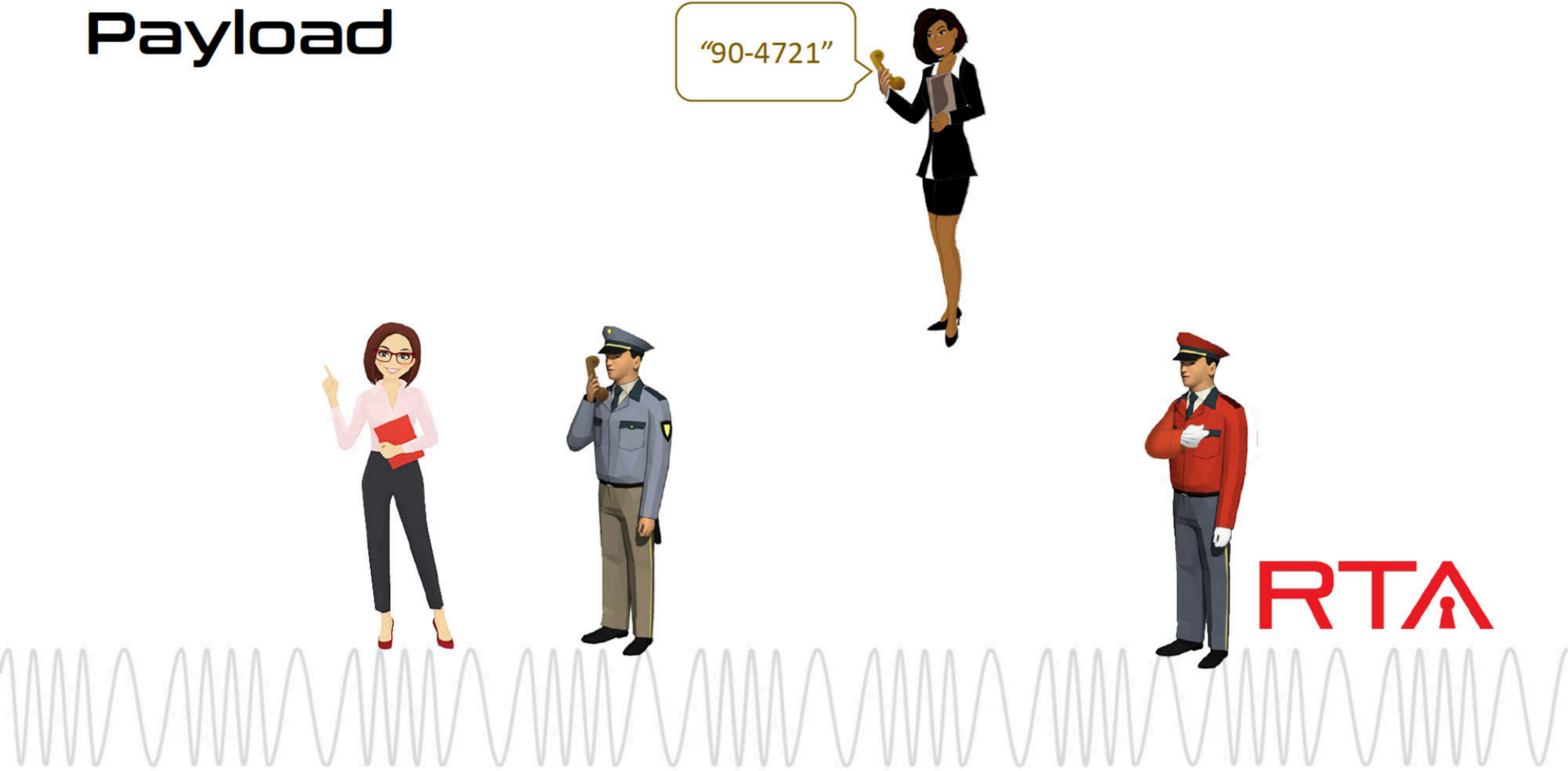
The Credential and the Reader Do Crypto Together

With PACS Payload Unlocked, The Credential Speaks

RTA

The Reader Transmits the PACS Payload

The Controller Receives the PACS Payload

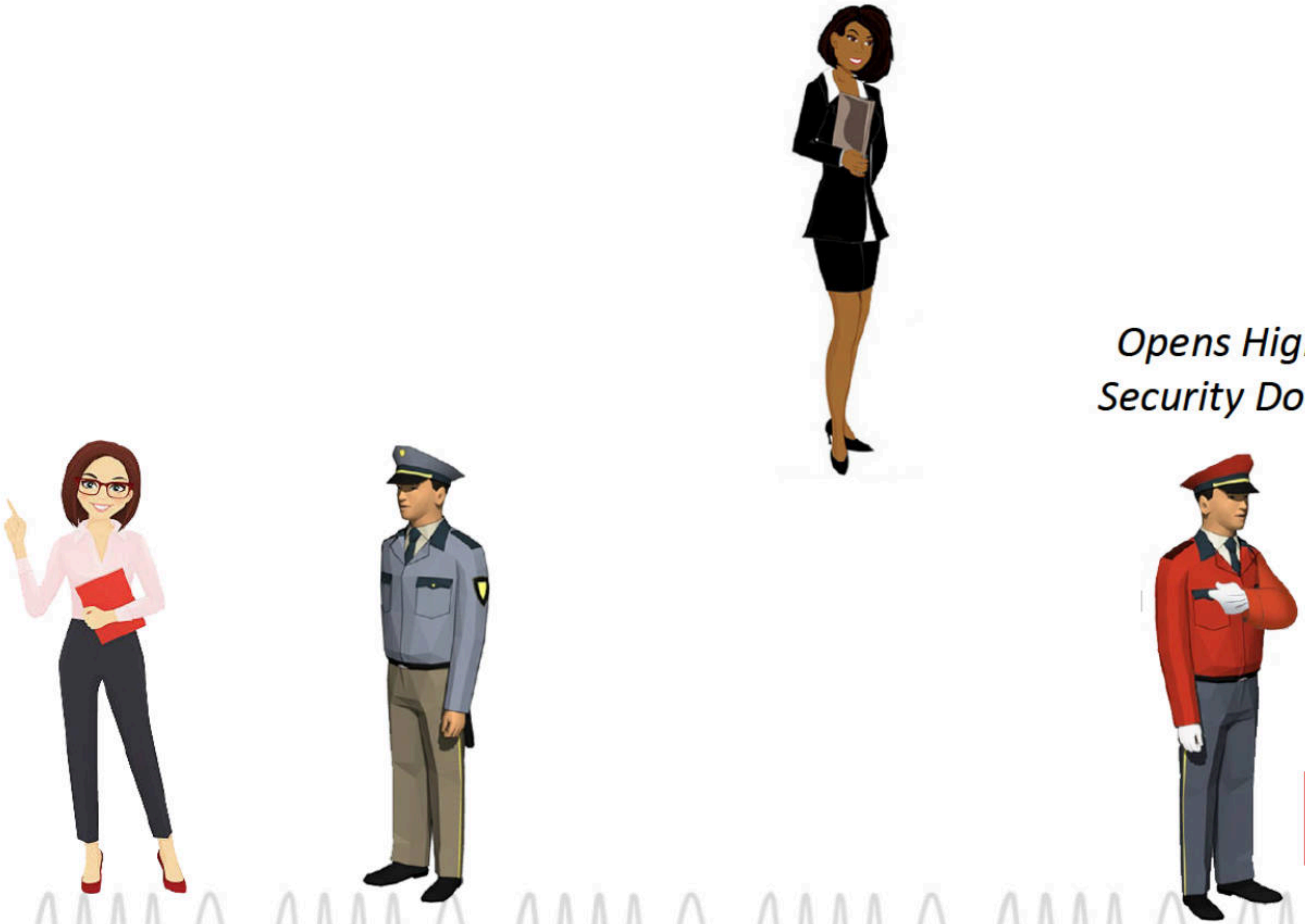


RTA

The Controller Checks Their User Permission Table

The Controller Activates the Door Relay

Access is Granted



So many credentials

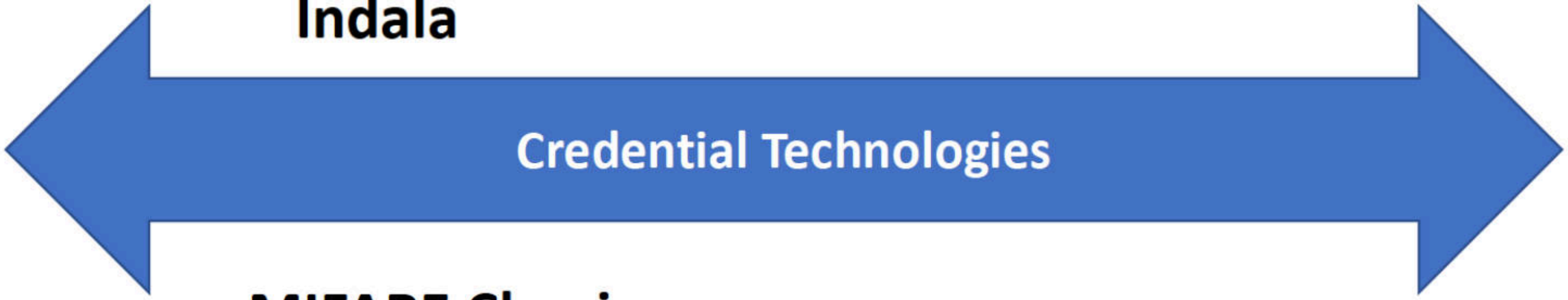
ioProx AWID

ISOProx Hitag 2 Hitag 1 / S

Magstripe EM4102

Indala

Less Secure*



More Secure*

MIFARE Classic

HID iCLASS Seos

Wiegand Swipe

HID iCLASS SE

HID iCLASS

NXP MIFARE DESFire (EV1, EV2, EV3)

* Not Scientific at ALL - Depends on Implementation

Enterprise Access Control Systems

Credentials

Readers

Lock Mechanisms

Sensors

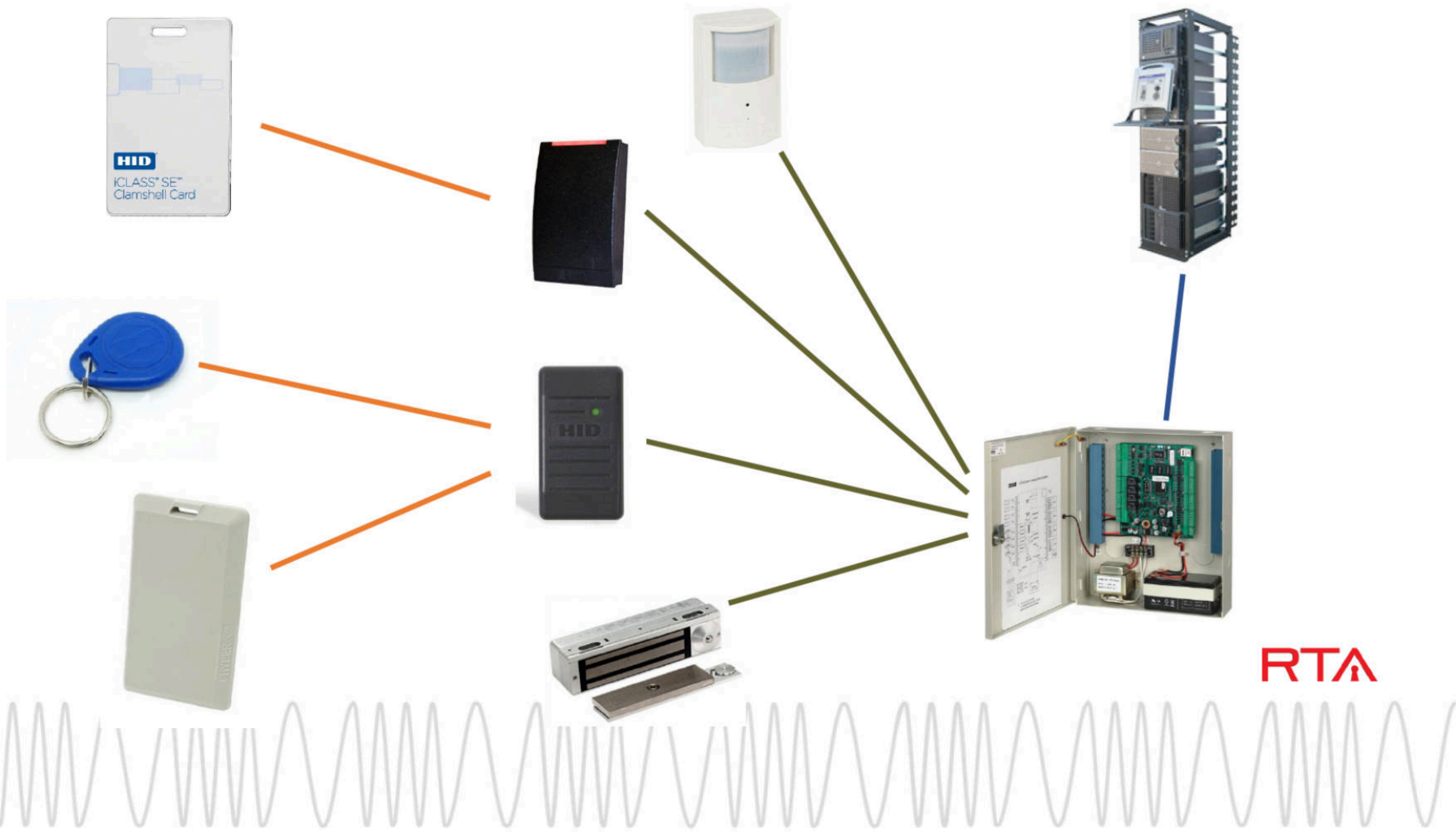
Door Controller Panel (Or Panels)

Management Software

Access Control Systems – Credential Communication

RTA

Enterprise Access Control System Communication



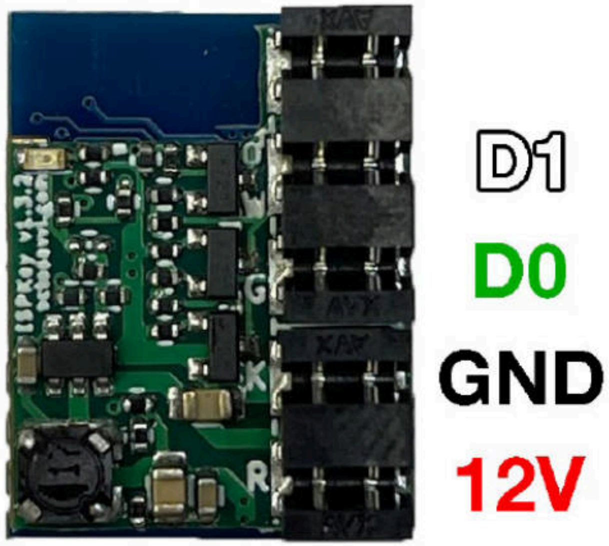
Tools of The Trade

Proxmark3

- Original by [Jonathan Westhues]
- Many, MANY, Hardware Variants
  - Some Good, Some Bad
- RFID Swiss Army Knife
  - Software-Defined LF and HF Reader/Writer
- Primarily a Research Tool, Not Red Team Tool
  - Latest Hardware (RDV4) Enables Red Teaming
  - Battery & Bluetooth Add-On Available
    - *Bluetooth 2.0 Only

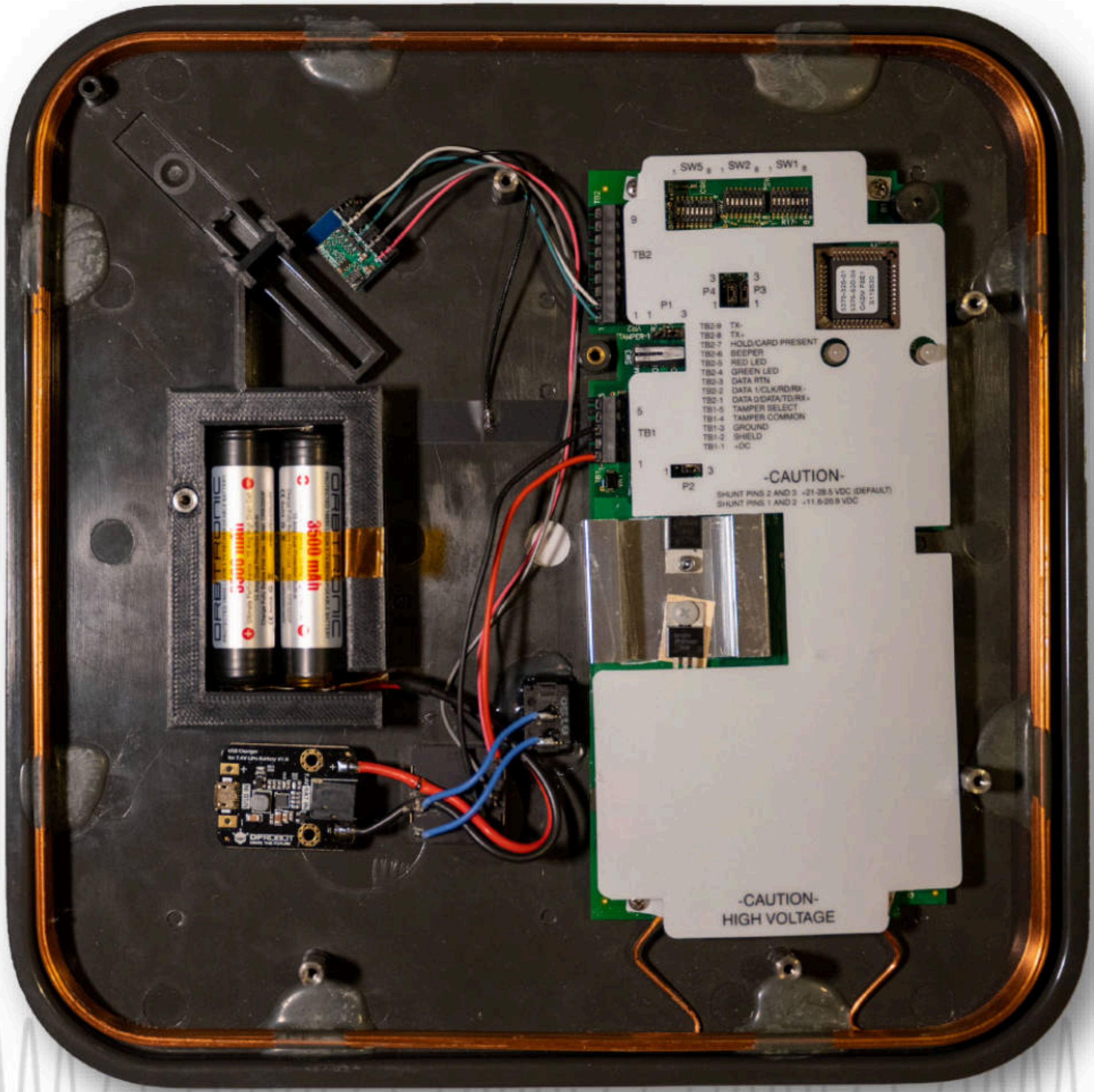
ESP Key

- Original Hardware / Software by Octosavvi
- Wiegand Interception / Replay Implant
- Alternatives Available (BLEKey, RFID Tool, Etc.)
- Optimized for Field Deployment
- Stores Credentials Sent by Reader to Door Controller
- Fast and Easy way to Weaponize any Reader!

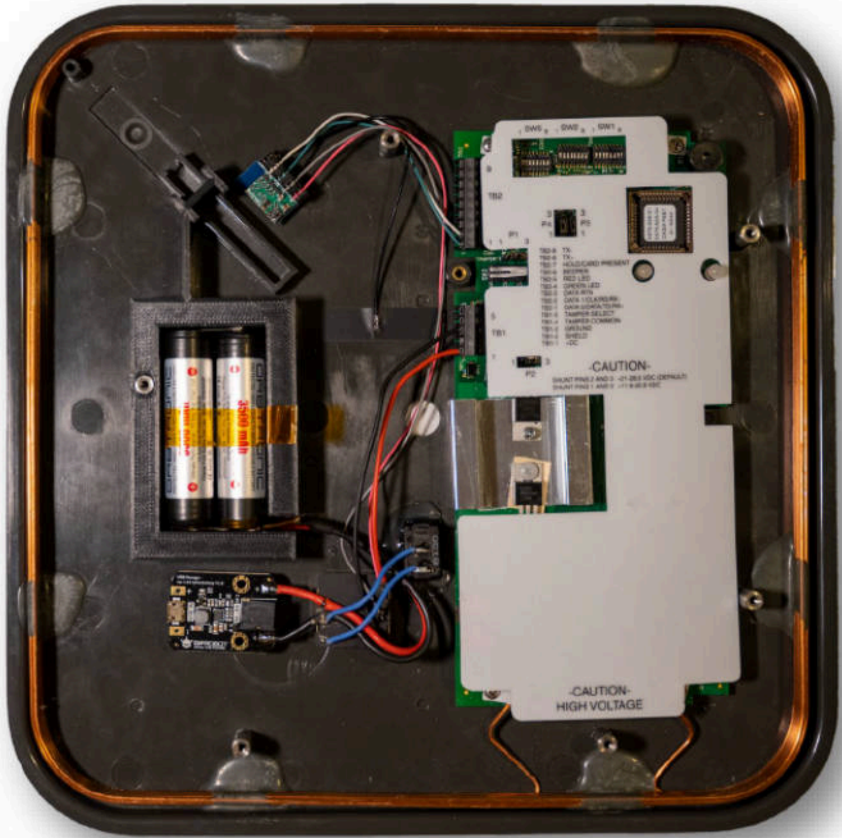


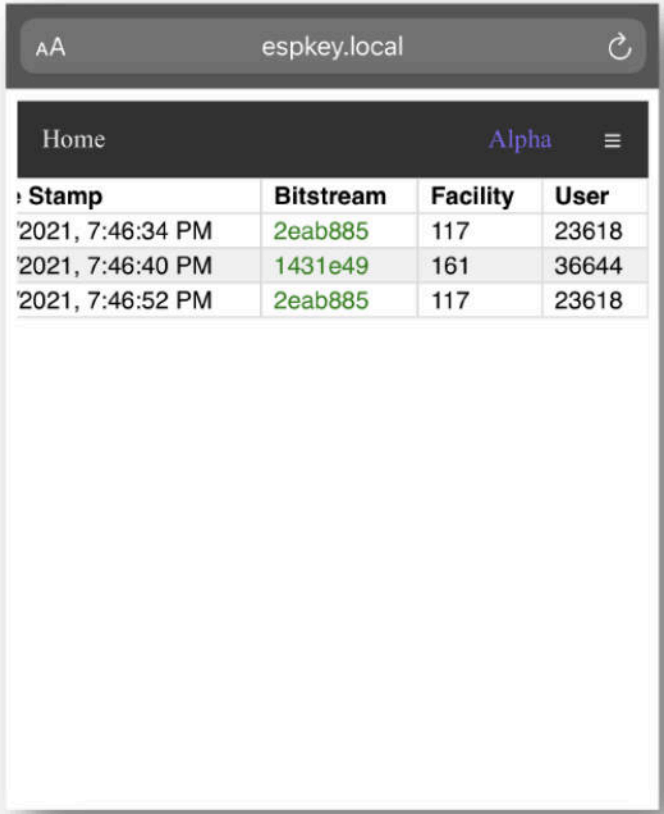
Weaponized Readers

- Very Old Concept
- Most Reliable Reads
- Countless Flavors Available
  - RavenHID
  - Tastic RFID Thief
  - Wiegotcha
- Off-the-Shelf Reader
- Simply Add ESPKey and Battery to Any Reader



Typical Workflow





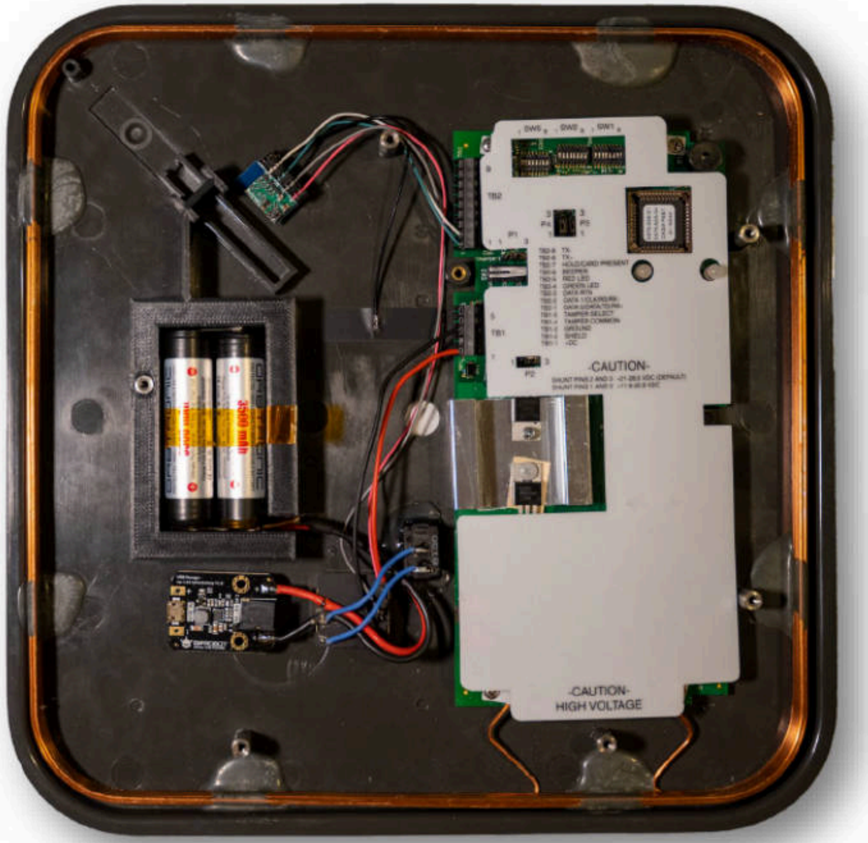
Stamp	Bitstream	Facility	User
2021, 7:46:34 PM	2eab885	117	23618
2021, 7:46:40 PM	1431e49	161	36644
2021, 7:46:52 PM	2eab885	117	23618

How do we improve the experience in the field?

Automation!

How can we glue these?

Just add some Pi!

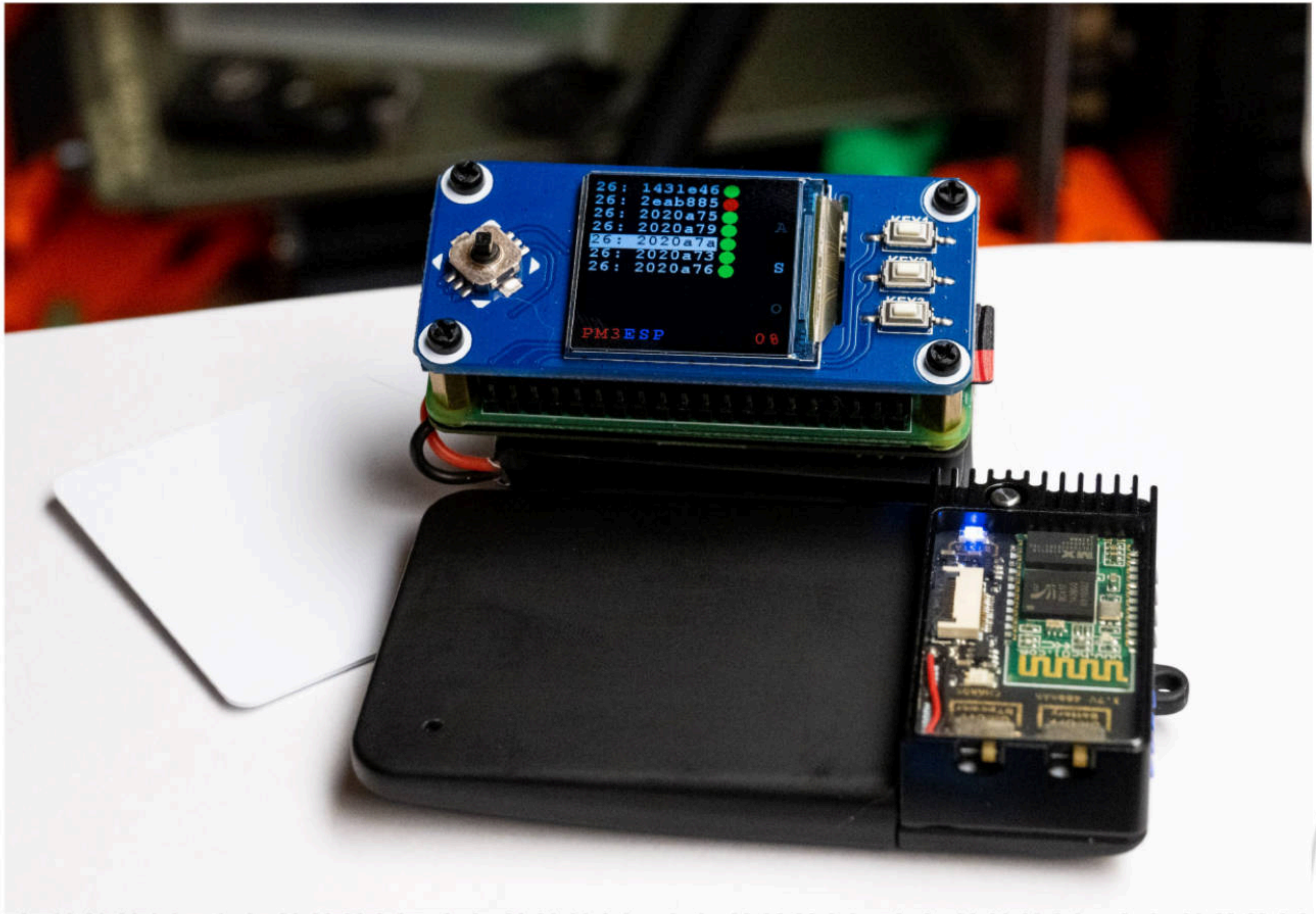


Introducing: Odo

Introducing: Odo

- Open-source framework to coordinate tools already in your kit
- Credential read by a weaponized reader is automatically cloned to a badge
- Modular framework based on a JSON over MQTT API
    - Language agnostic plugins can communicate
    - Credential producers (ESPKey, UI, etc…)
    - Credential consumers (Proxmark3, Database, Display, Haptics)

It Gets Better with Hats and Haptics



Demo Time

How can I make one?

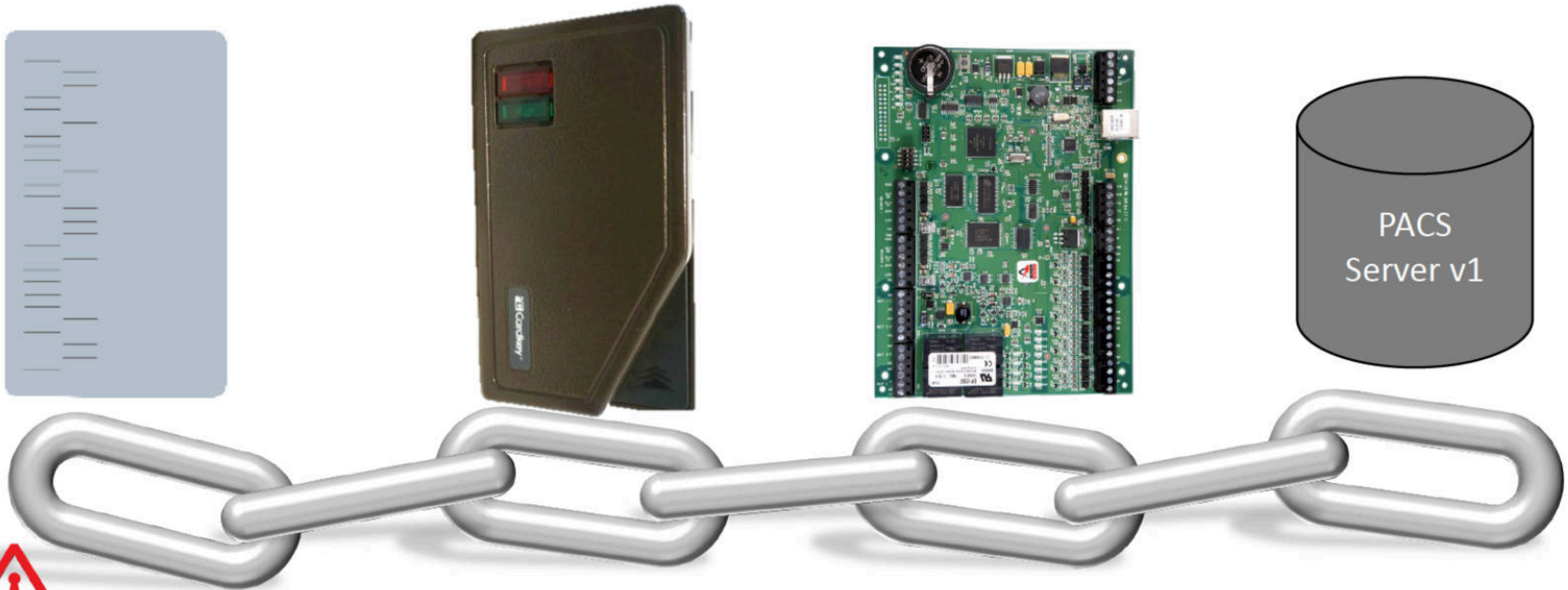
- Raspberry Pi Zero W
  - Cheap and Readily Available
- PiSugar 2 1200 mAh UPS
  - For Optimum Size and Convenience
- Waveshare 240x240 1.3inch IPS LCD Display Hat
  - Interface for Mode Switching, Data Display & Selection
- Odo
  - Open source on GitHub: https://github.com/Red-Team-Alliance/Odo

Contribute to Odo! (it's a framework)

- Potential Credential Producers
  - BLEKey
  - ESP RFID Tool
  - Wiegotcha
  - Telephoto Lens + OCR
- Potential Credential Consumers
  - Chameleon Mini
  - Libnfc
  - Emutag
- Support for Alternate Displays / Hats
- New Feedback and Control Mechanisms
  - Smart Watch Support
  - Android / iOS Apps
  - Haptic Feedback Vests

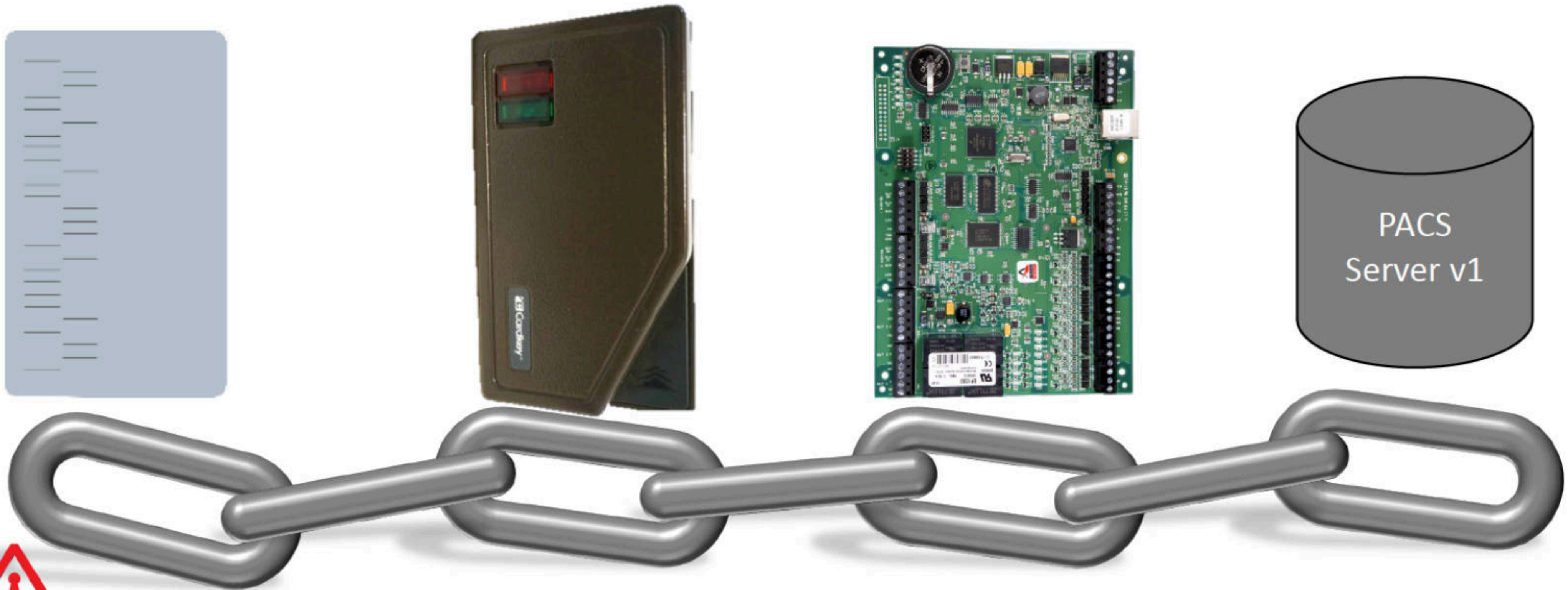
Evolution of PACS

The Physical Access Control Chain of Trust



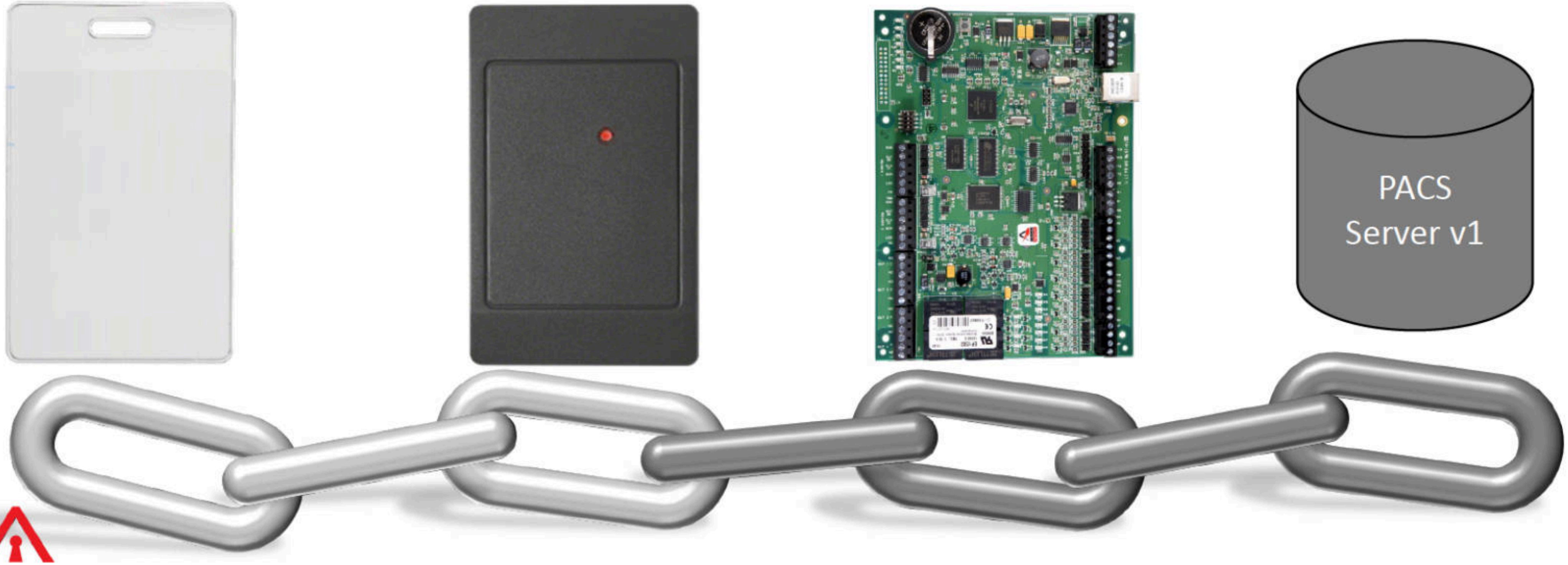
RTA

Chain of Trust: Components Age



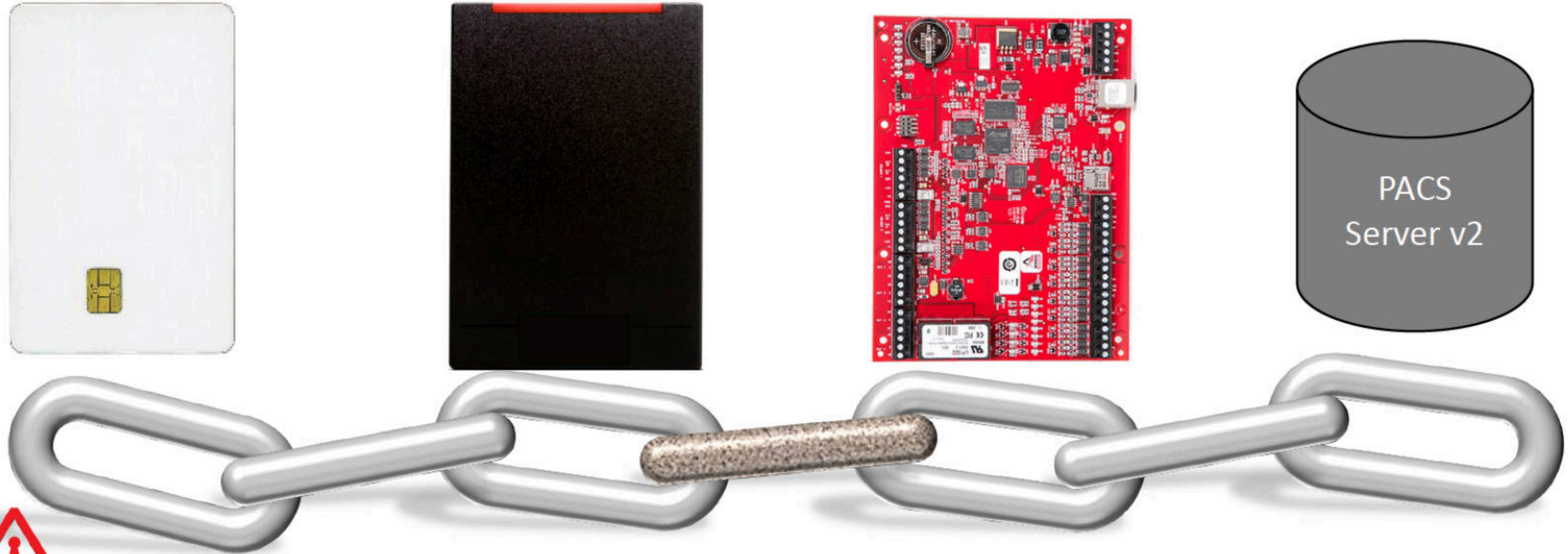
RTA

Chain of Trust: Components Replaced or Upgraded

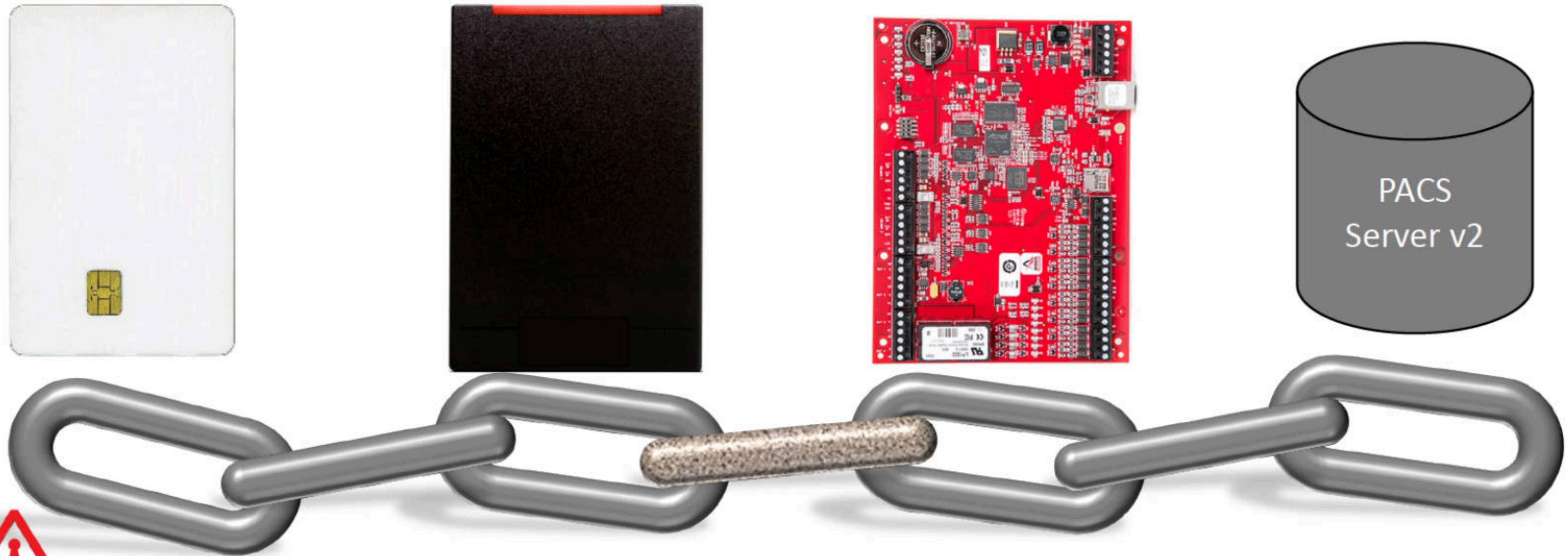


Chain of Trust: Components Continue Aging

Chain of Trust: Upgrades Continue



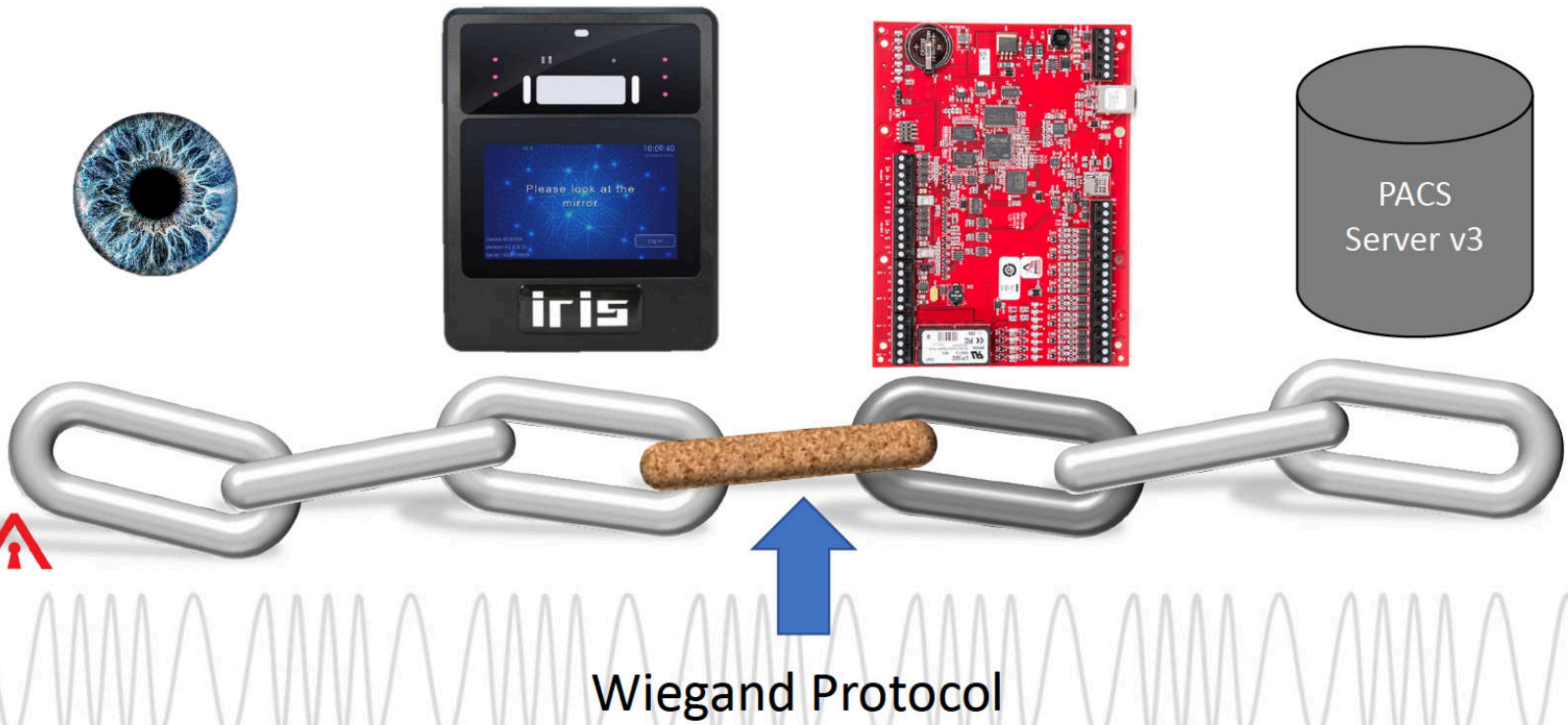
Chain of Trust: Aging Continues



RTA

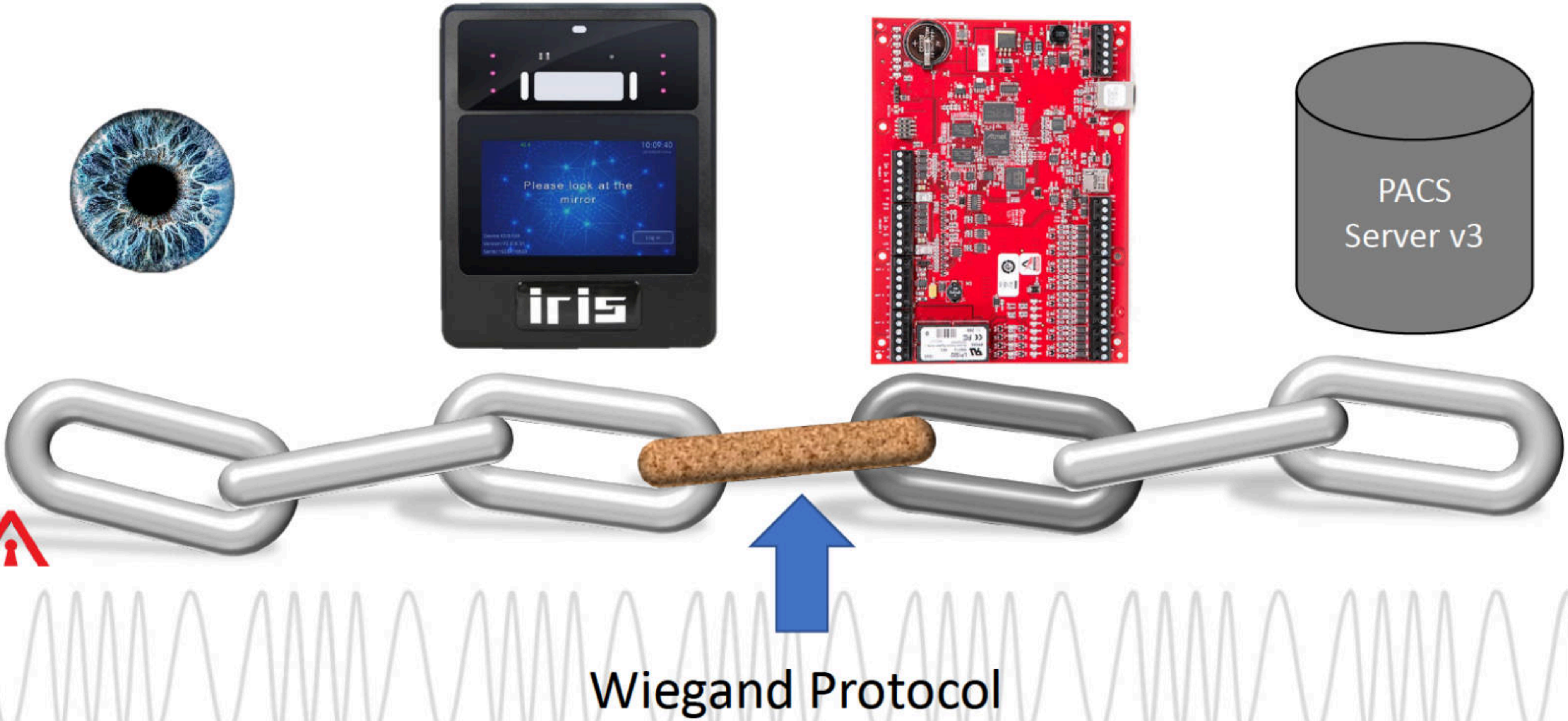
Chain of Trust: Partial Solutions Obscure Problems

Chain of Trust: Why should this be of concern?

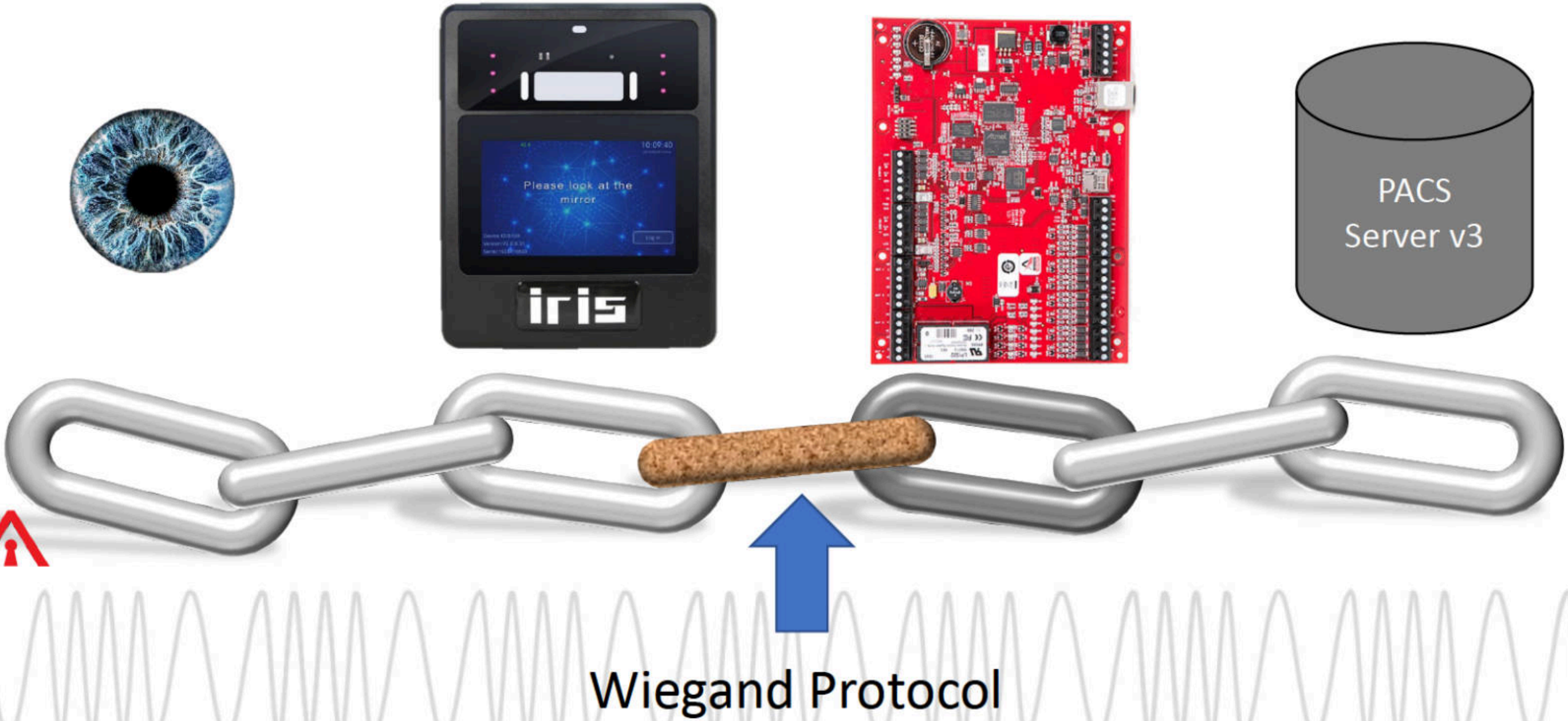


RTA

Chain of Trust: Only as Strong as the Weakest Link



Chain of Trust: Replace The Weak Links



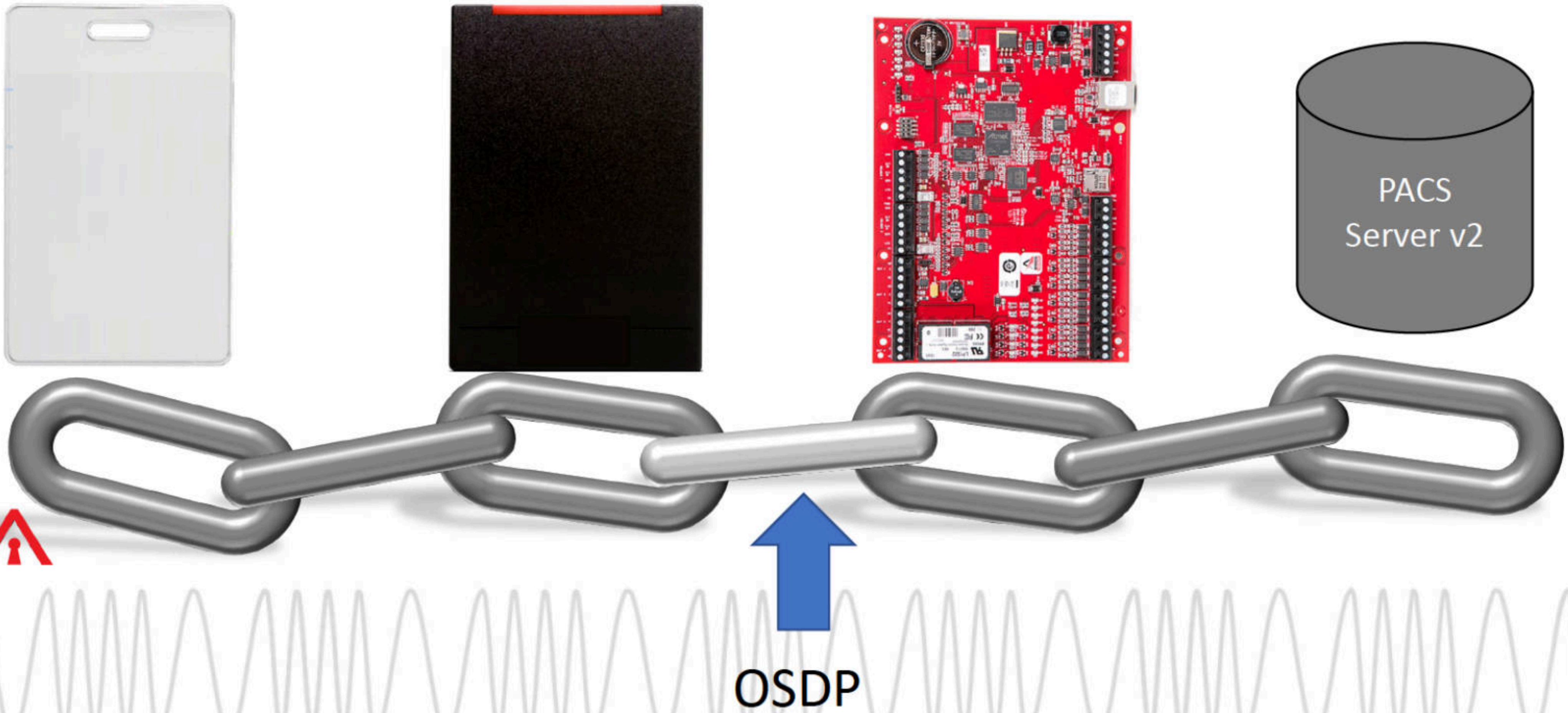
OSDP Killed the Wiegand Star

- Wiegand is old, one way, unencrypted, attacked in the wild
  - Low skill attack
  - Still used as part of new installations today
- OSDP Offers Secure Bi-Directional Rx/Tx
- OSDP is Still Relatively New to Installers
- OSDP Support in Software Not Fully Mature

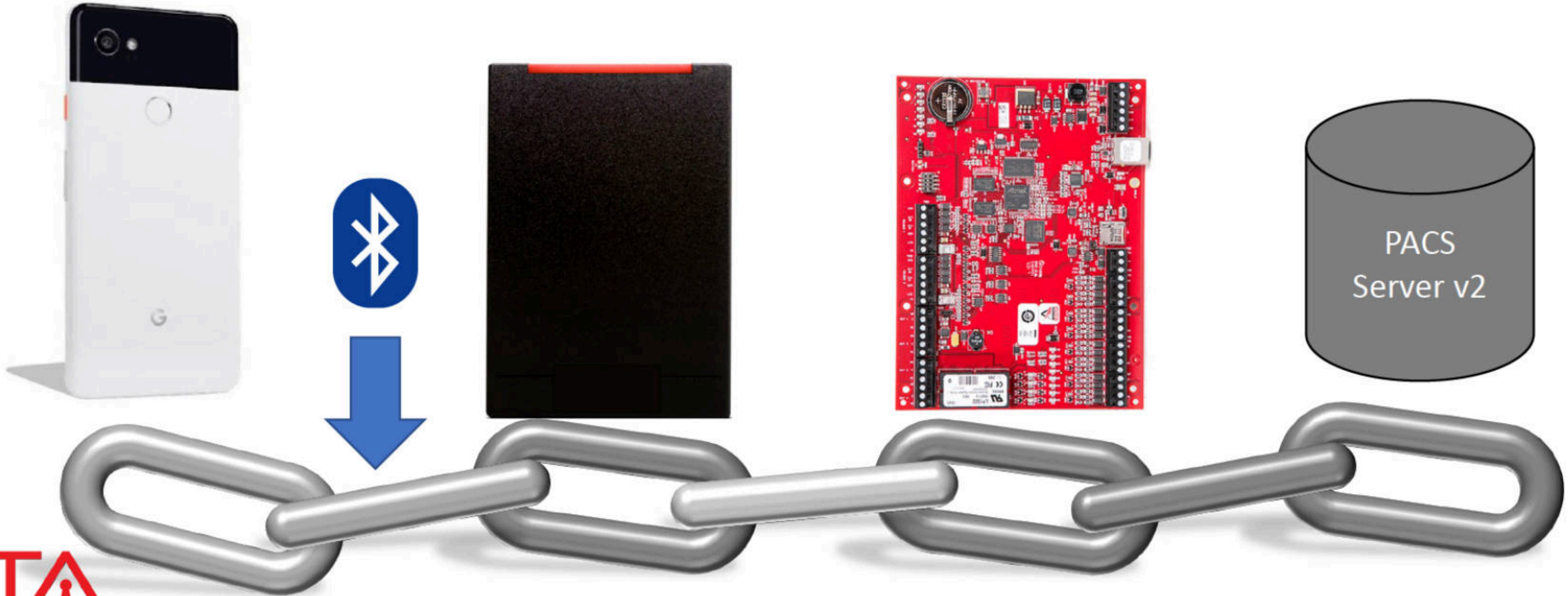
OSDP™

RTA

Chain of Trust: Aging Continues



Chain of Trust: Aging Continues



Mobile Credentials Are the New Black

- Mobile Credentials are the New Thing
- NFC
  - Not Supported by All Smartphones
  - Until Recently Heavily Locked Down on iOS
- BLE
  - Nearly Ubiquitous Smartphone Support
  - Protocol Was Not Designed for This Purpose

Backwards Compatibility and Cost Efficiency

- Sounds great, but I don't want to replace my readers, what can I do?

OSDP / BLE Combo "Backpack"

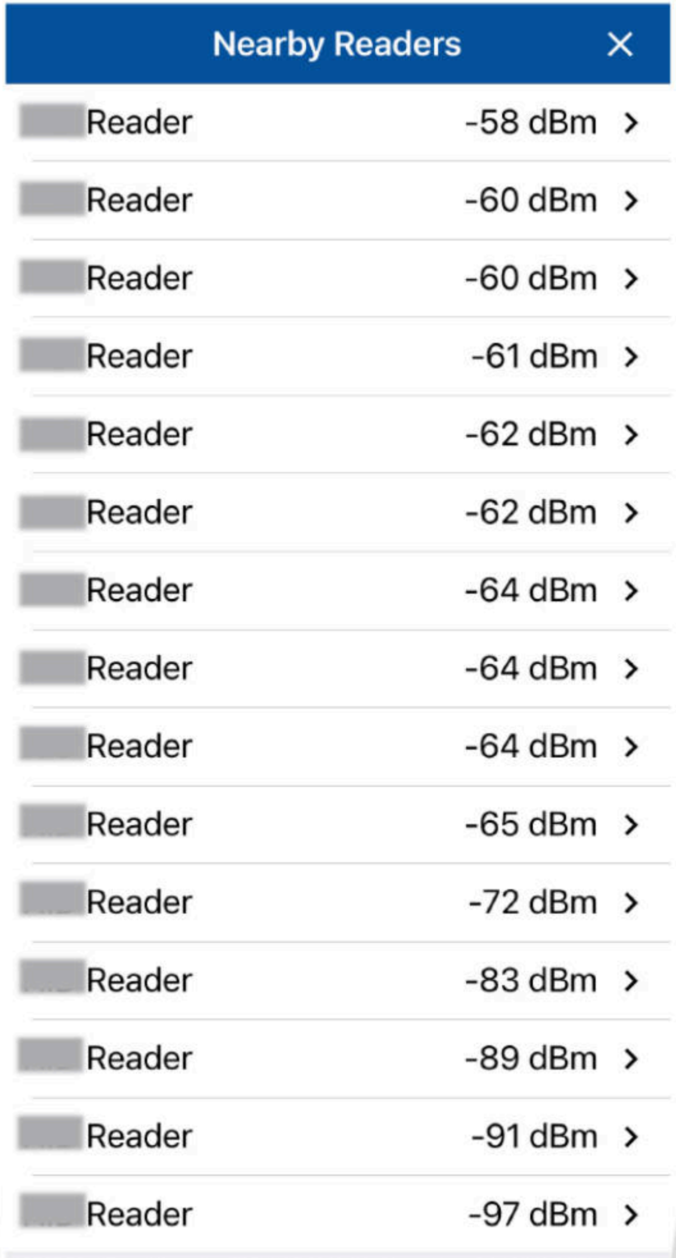
What Else Does This Add?

- Diagnostic Capability
- Firmware Upgrades
- Reconfiguration

Reader Manager Functionality

- Scans for Nearby BLE-enabled Readers
- Functions to Reconfigure Readers
  - View Current Reader Configuration
  - Change Reader Configuration
  - Add/Remove Credential Technologies
  - Enable / Disable Wiegand / OSDP, etc.

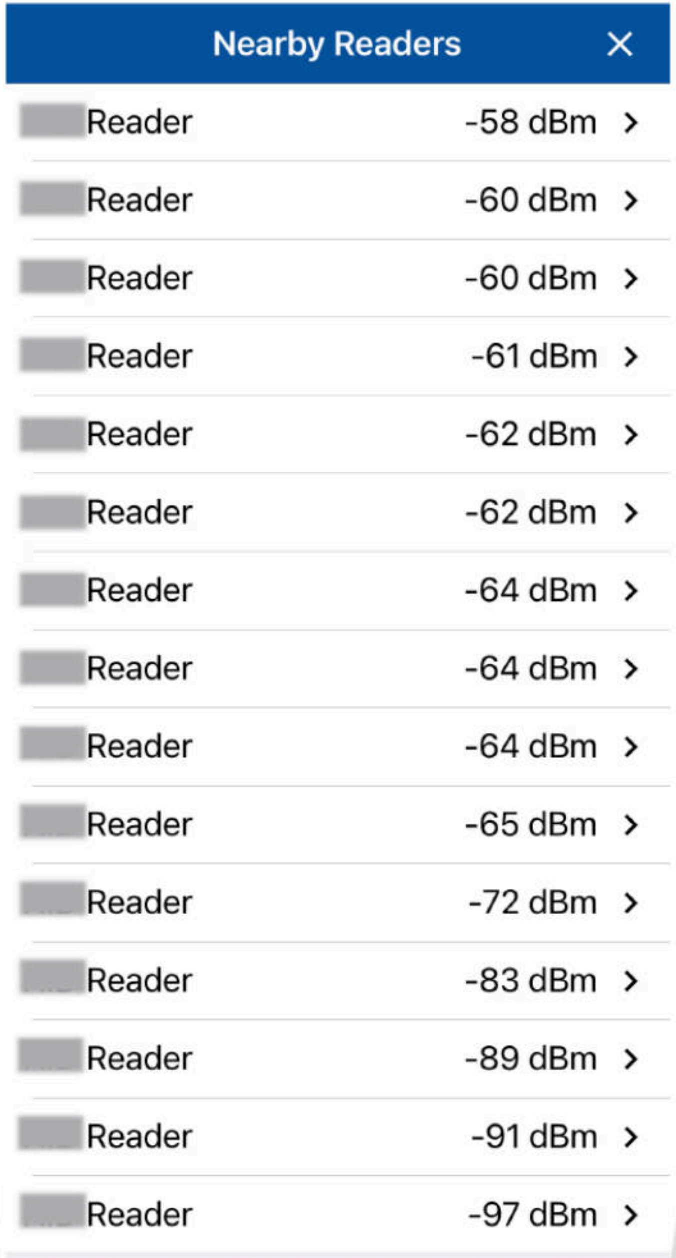
- ZOMG SO MANY READERZZZZ!!!111



Reader Manager Functionality

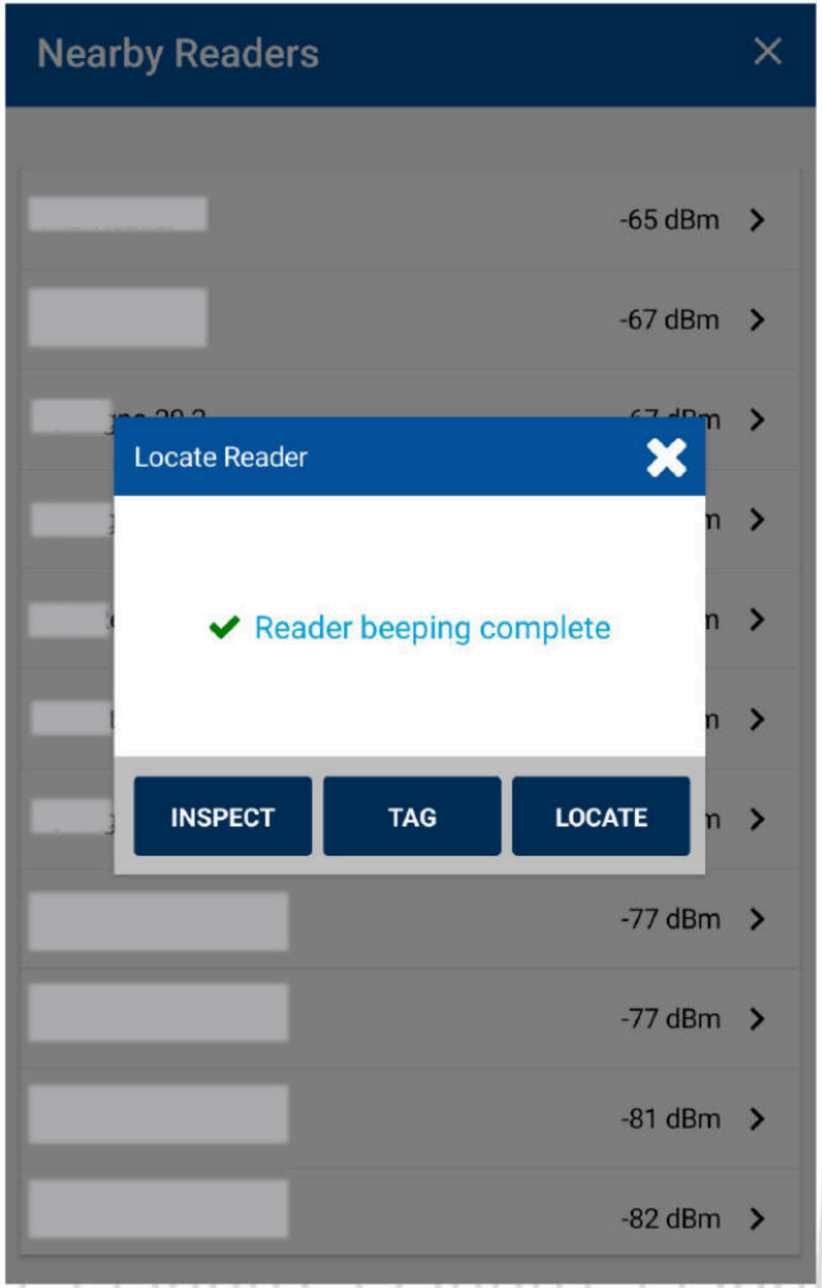
- Functions to Tell Readers Apart
    - Locate: Beep and Flash Reader LED
    - Tag: Renaming Readers

- How does it work in practice?



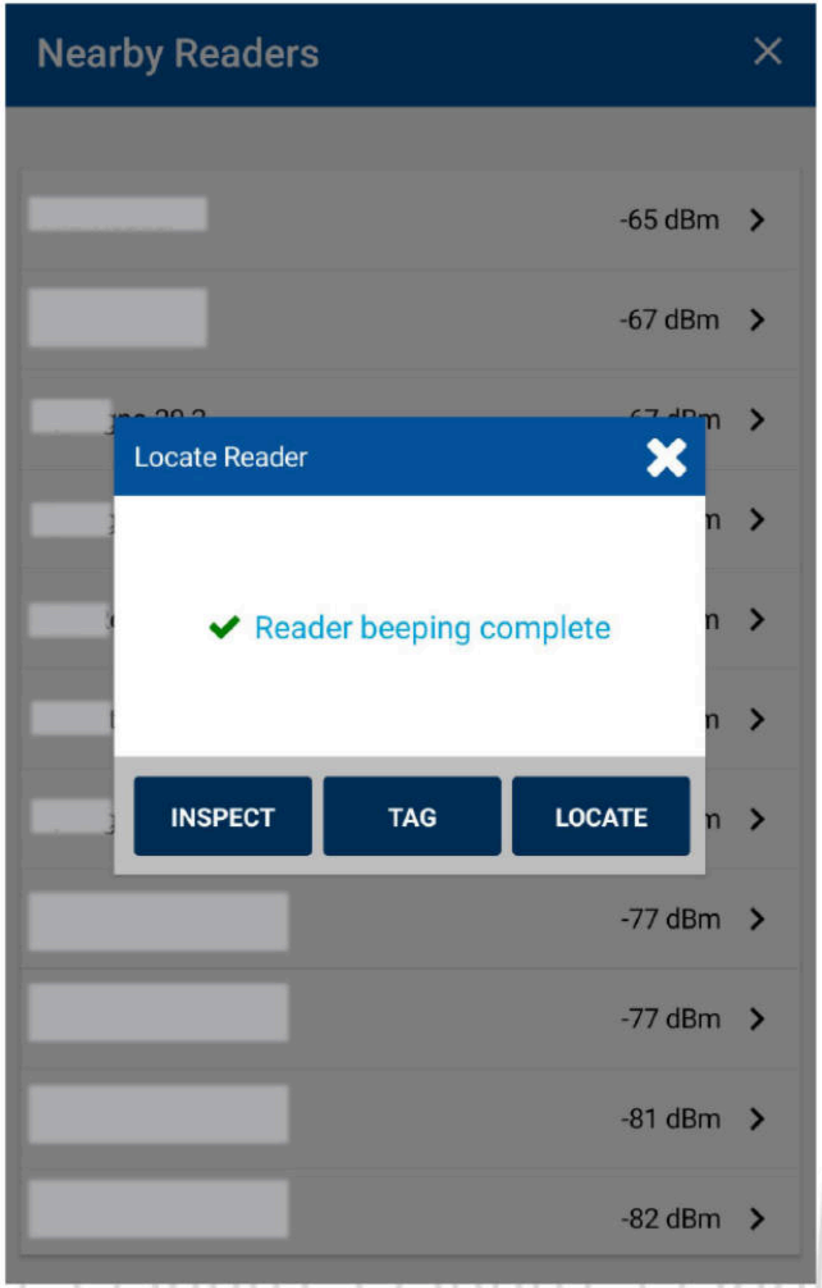
Reader Manager Security

- "Inspect" Functions Require Auth
  - Enabling / Disabling Credentials
  - LED Behavior
  - Output Protocols
- Many Changes Require Power Cycle / Reset
  - Readers Only Accept Changes for ~30s
- "Elite" Readers / Custom Keyed Readers
  - Changes Require Site-Specific "Admin" Key
  - Resists Unauthorized Changes to Reader



Reader Manager Security

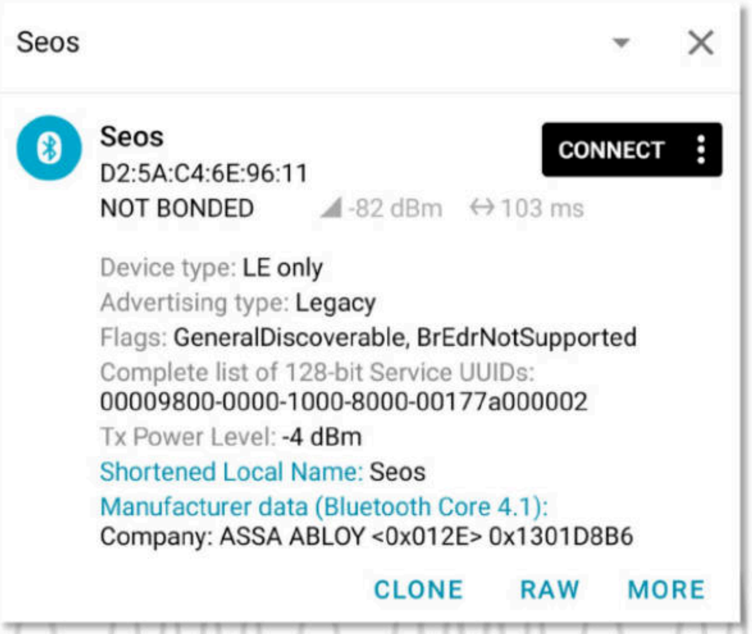
- Some Functions **Don't** Authenticate
  - Locate: Beep and Flash Reader LED
  - Tag: Renaming Readers (Locally)

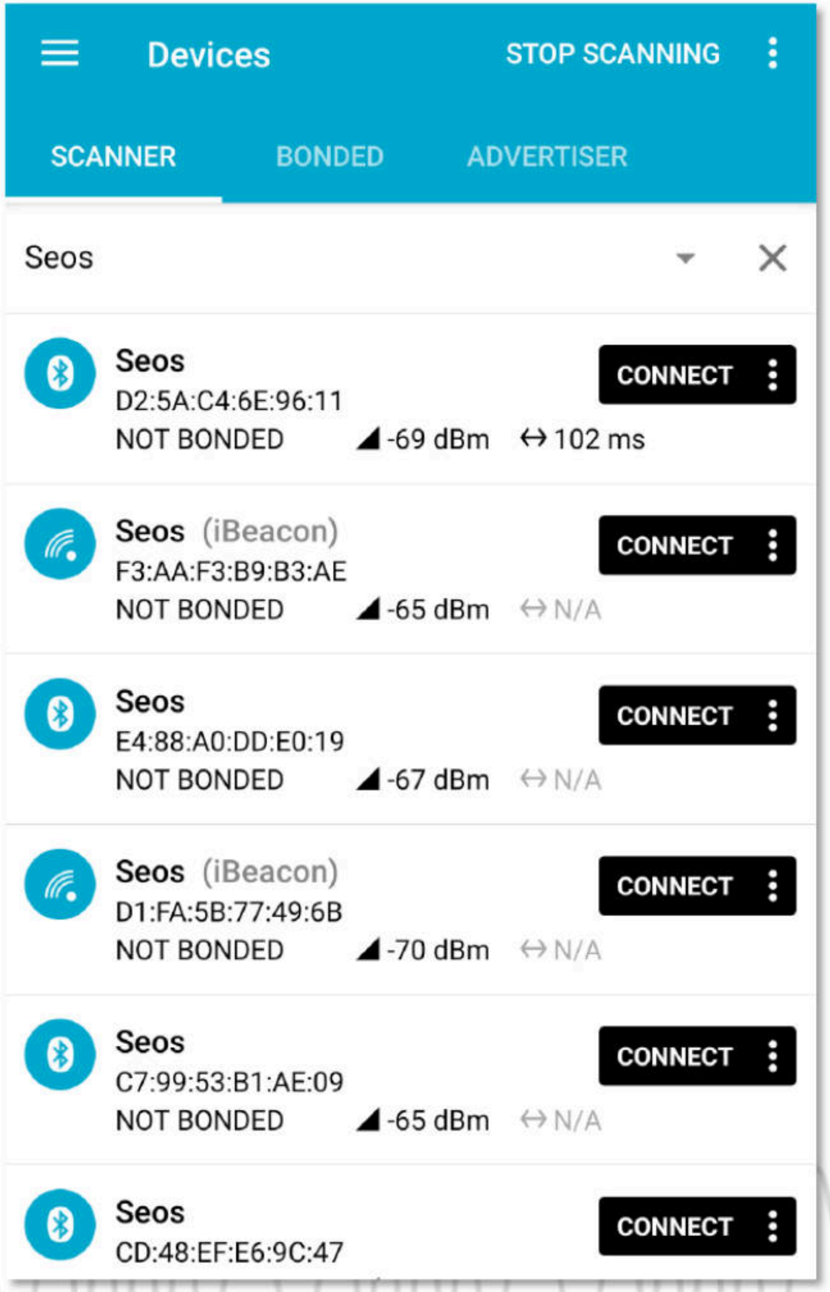


Hmm... Bluetooth...

BLE Interface

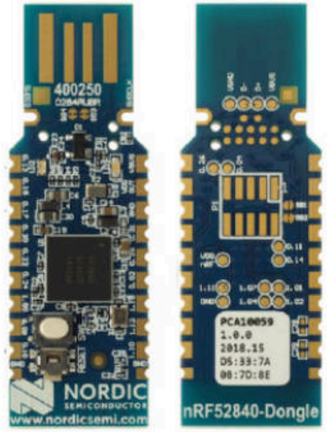
- Advertises a Single Service
- Service Has One
  "notify+writeWithoutResp" characteristic
- Upon Subscription Reader Sends Initial Message
- Aggressive Disconnect

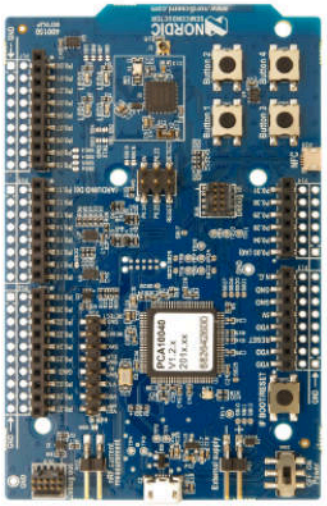




Under the hood

- What does that BLE conversation look like?
- Let’s sniff the air and find out
  - Pull out your nRF52DK
  - Load Nordic's [nRF Sniffer for Bluetooth LE]
  - 'Locate' a device
  - ...
  - Profit





BLE Conversation

- What does that BLE conversation look like? ISO 7816 APDUs?!?

Select AID A0000004400001010001

```
v Bluetooth Attribute Protocol
  > Opcode: Handle Value Notification (0x1b)
  > Handle: 0x000b (Unknown: Unknown)
    Value: c000a404000aa000000440000101000100

0000  02 01 20 18 00 14 00 04  00 1b 0b 00 c0 00 a4 04   ·· ····· ········
0010  00 0a a0 00 00 04 40 00  01 01 00 01 00            ······@· ·····
```

Not Found 6A82

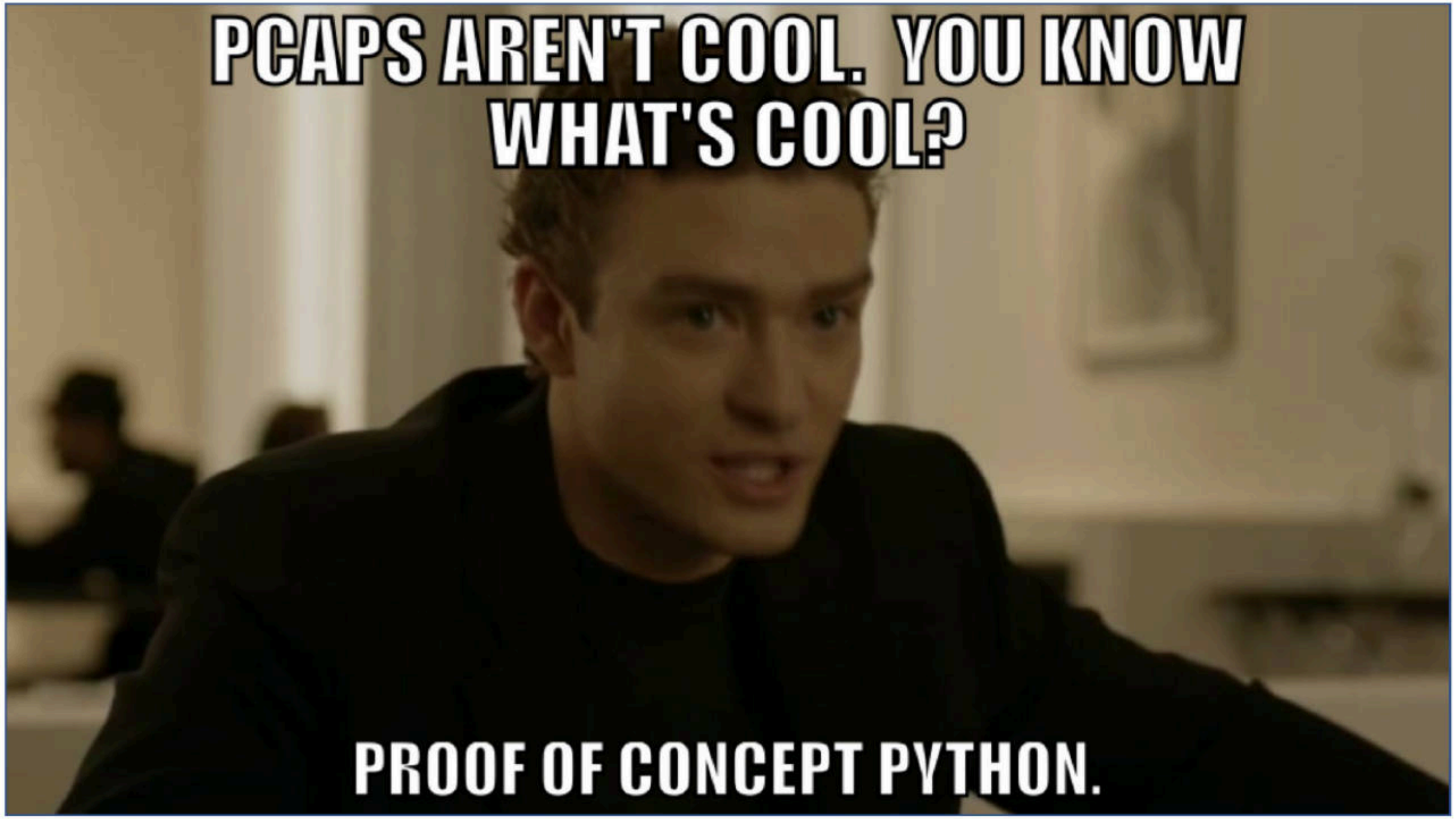
```
v Bluetooth Attribute Protocol
  > Opcode: Write Command (0x52)
  > Handle: 0x000b (Unknown: Unknown)
    Value: c06a82

0000  02 01 00 0a 00 06 00 04  00 52 0b 00 c0 6a 82      ········ ·R··j·
```

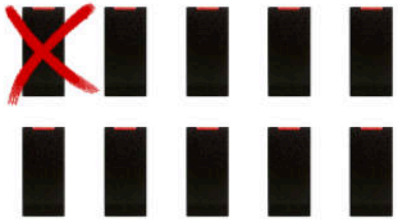
You might be wondering what's with all readers?

Why are they blinking?

- Field Detector Cards from Proxgrind and RRG!
- LED's Powered by EM Field for Blinkie Blinkie Action
- Separate LED Colors and Circuits for LF and HF
- Red = 125kHz Field Detected
- White = 13.56MHz Field Detected

Pcaps? That's boring



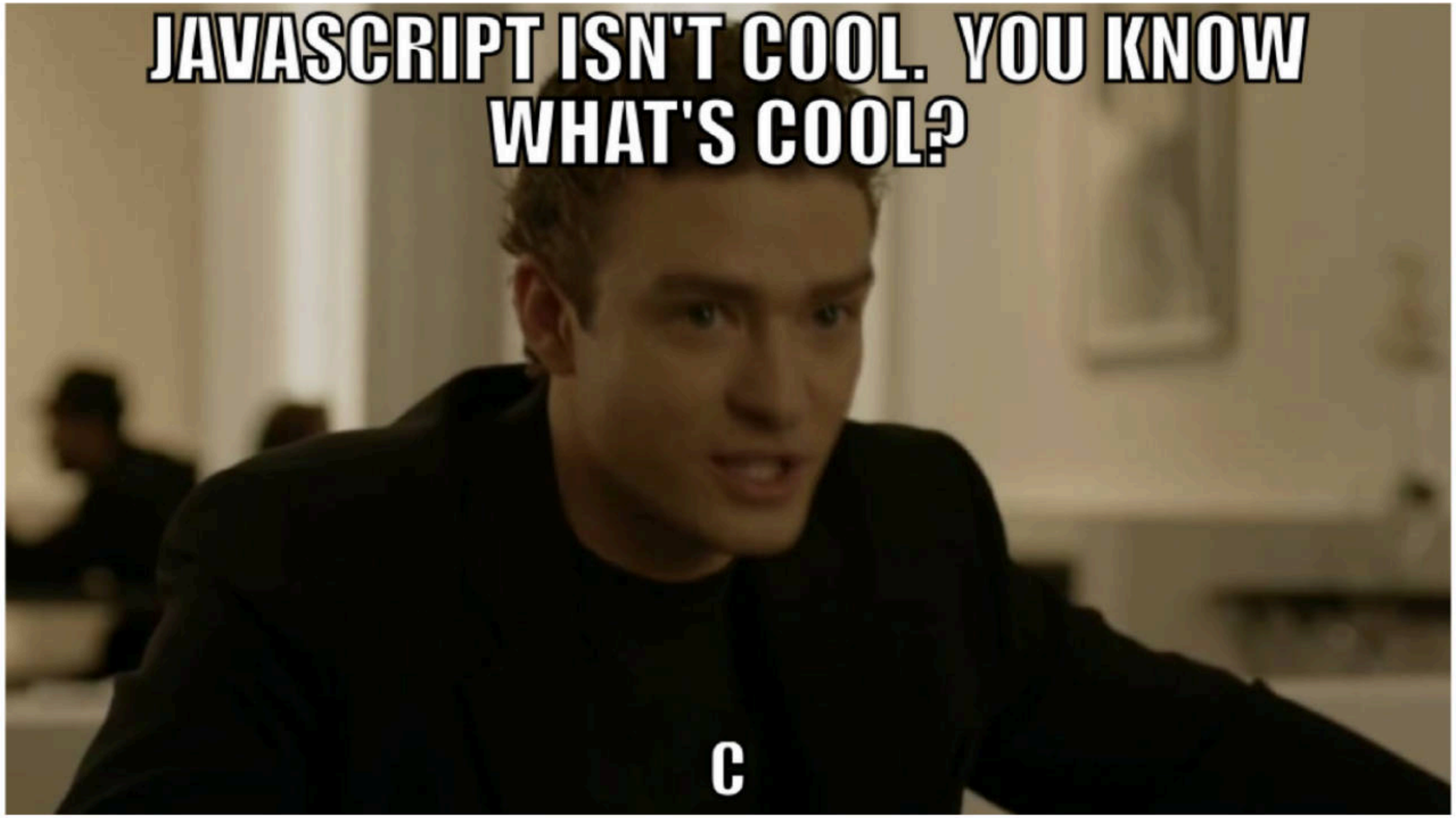


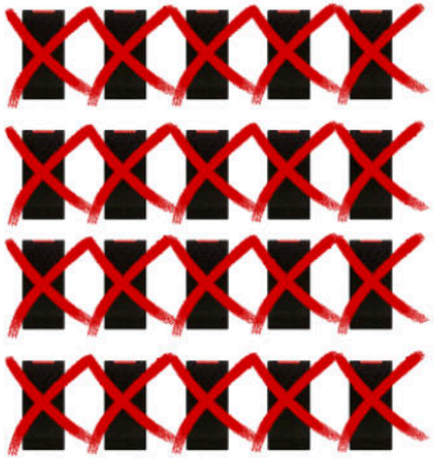
```
service_uuid = "00009800-0000-1000-8000-00177a000002"
char_uuid = "0000aa00-0000-1000-8000-00177a000002"
char_config_uuid = "2902" # 0x2902

responses = {
            "c000a404000aa000000440000101000100": [b"\xc0\x
            "c000a404000aa00000382002d00010100": [b"\xc0\x
            "c000a404000aa00000382002f00010100": [b"\xc0\x
            "c000da55000e0102018b02017d063dbfc51970f2": [b"
            "c000da55000e0102052a02052a069e13a6551d73": [b"
            "c000ca00000000": [
                b"\x81\x44\x3e\x44\x00\x00\x00\xa6\x13\xa1\
                b"\x40\x01\x01\x83\x01\x00\x84\x01\x01\x90\
                ],
```

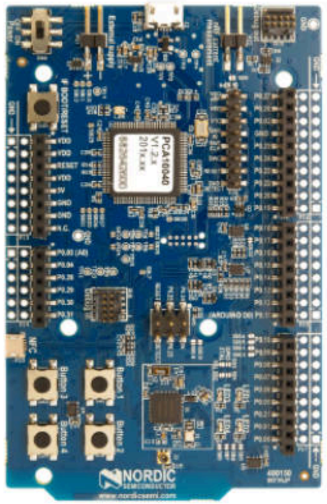
One? Please, this is DefCon

```
async function onPeripheral(peripheral) {
  const { advertisement, uuid } = peripheral;
  const { localName, serviceUuids, txPowerLevel } = advertisement;
  console.log(`Saw ${localName}`);

  if (denyList.includes(uuid)) {
    console.log("Explicitly excluded reader on deny list", uuid);
    return;
  }

  if (serviceUuids && serviceUuids.includes(seosService)) {
    await noble.stopScanningAsync();
    console.log(`Connecting to ${uuid}`);
```

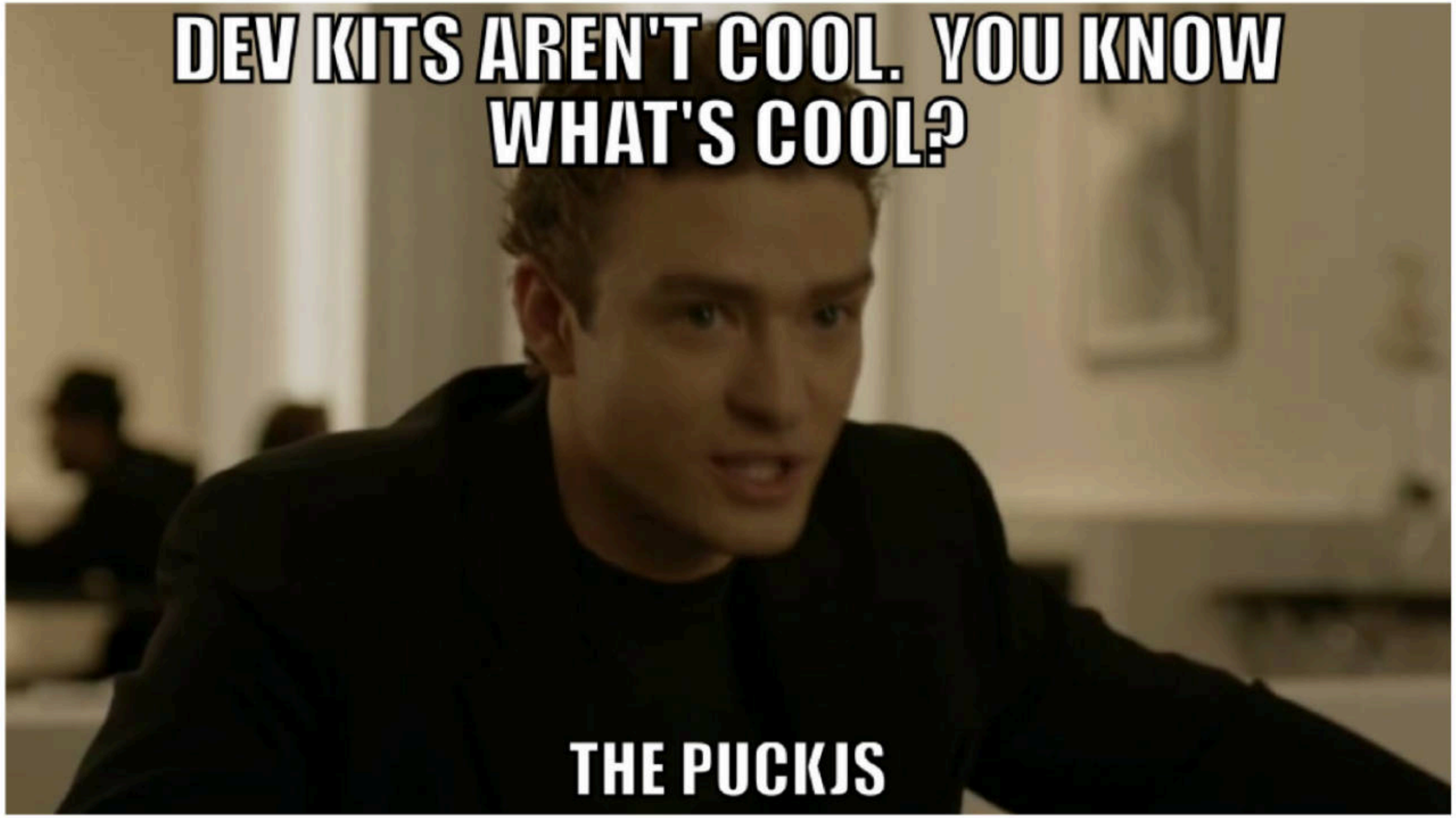
Javascript, what's next, Lua?

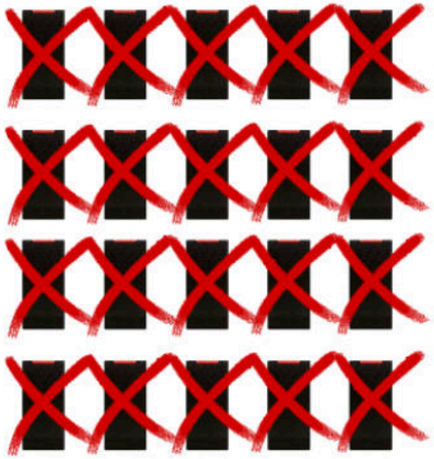






A dev kit? That's cheating





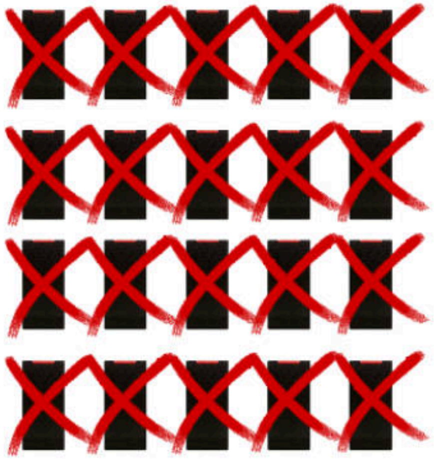
Demo Time

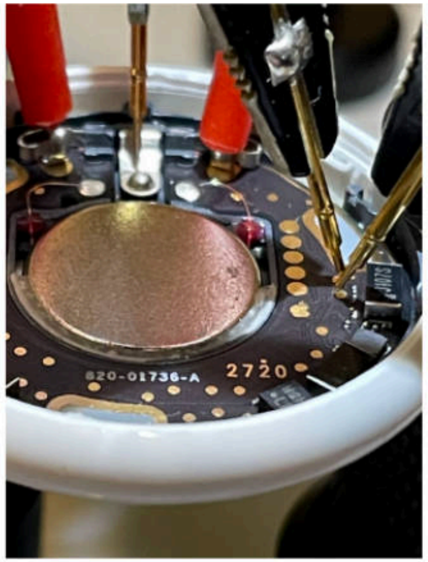
Why did they stop blinking?

- EM Field Turned Off by Reader
- Credential Cannot Power On
- Reader is Not Processing Media

What else has an nRF52?

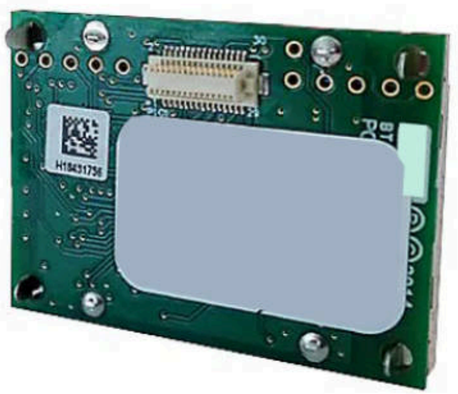
What else has an nRF52?





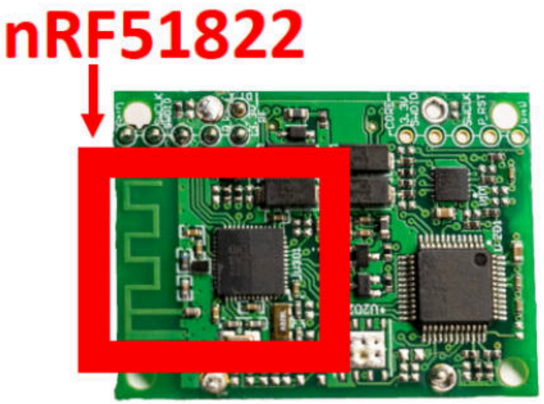
Demo Time

Bring it home.



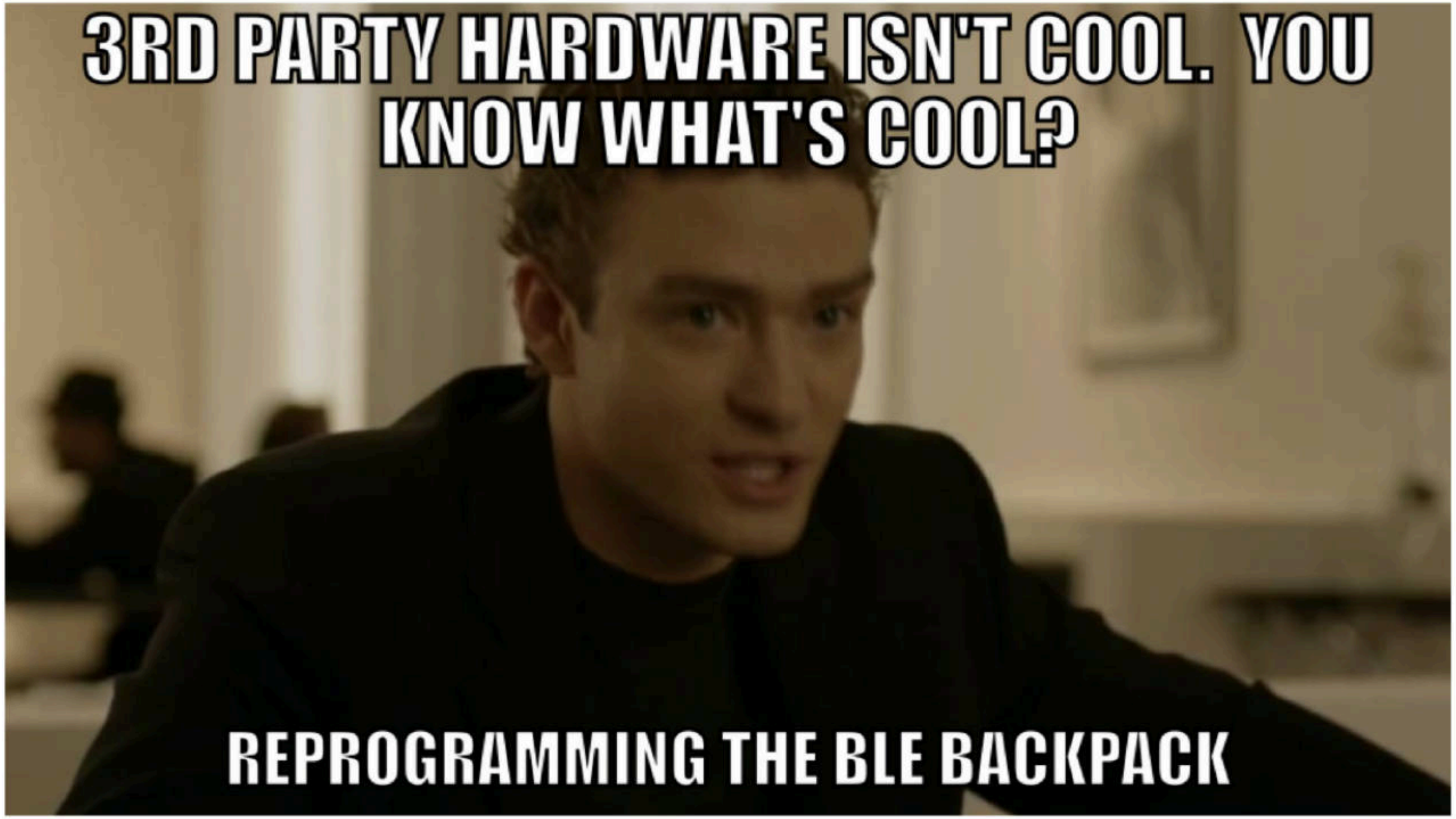
Remember the backpack that adds BLE?

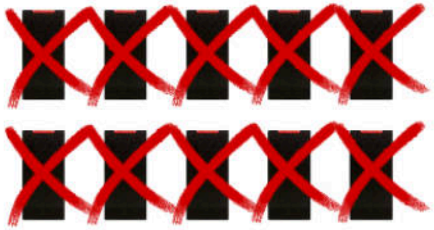
Bring it home.

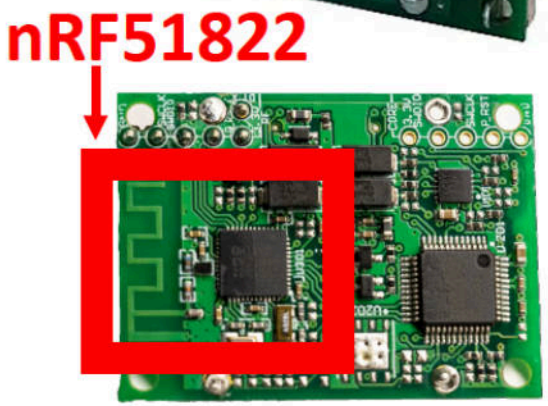


Can we reprogram it?

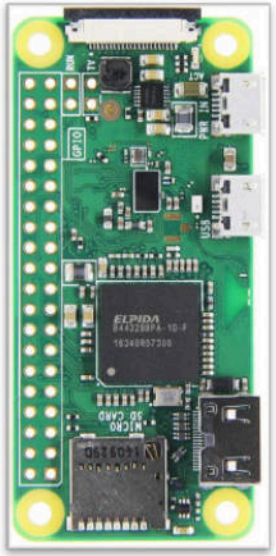
Bring it home.

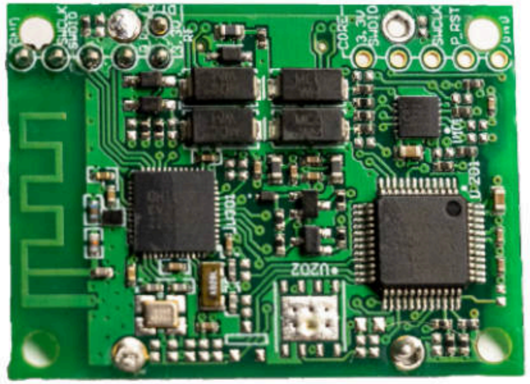


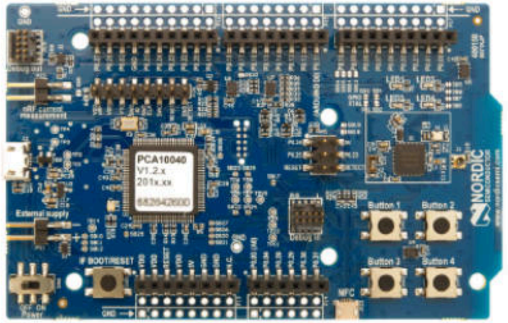


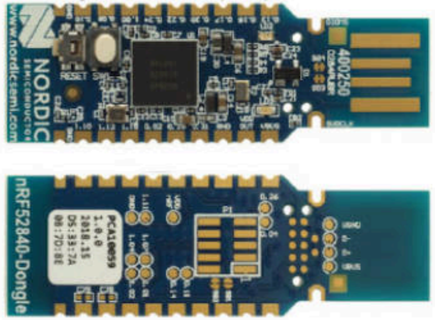


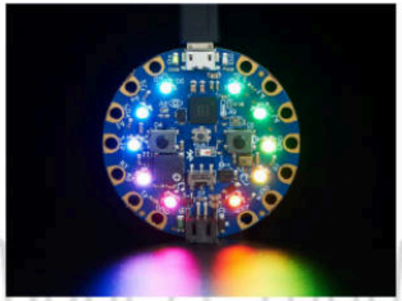
BLEepSleep Devices











Idea from:
@netspooky

So what does it all mean?

Practical Impacts

- Selective or Area-Wide Denial of Service
- Disable Access to Key Ingress/Egress Points
  - Turnstiles
  - Security Vestibules
  - Equipment Rooms
- Annoy the Crap Out of People by Beeping All Readers
- Engage DoS Post-Entry to Evade Security
- Ghost Mode
  - Slip a Device Into Target User’s Bag to DoS 2 Closest Readers
  - User Becomes “Invisible” to Readers

Mitigations

- Vendor Response
  - Working on Upcoming Firmware Update
    - Currently Requires Use of Mobile App at Each Reader
  - Future Updates via OSDP Functions (For Supported HW)
- Short-Term Mitigation
  - Educate Security Staff and Response Teams
  - Some Customers May Opt to Disable BLE Functionality
  - Affected Customers Should Reach Out to Their Account Manager for Guidance
  - Customers Not Using Mobile Credentials May Inquire about ODSP-Only Backpacks

Acknowledgments

- Thanks to HID For Listening and Responding
- Christian ”Iceman” Herrmann
- Our friends at the RF Village
- RFID Research Group / I-Copy X
- Gordon Williams (ESPurino)
- RFID Hacking Discord 

Thank you!

- We are
  - Babak Javadi: @babakjavadi
  - Nick Draffen: @tcprst
  - Eric Betts: @aguynamedbettse
  - Anže Jenšterle: @applejacksec
- You are
  - Possibly hungover
  - Amazed
  - Going to investigate the Proxmark3 RDV4 with BlueShark
  - Going to vet your PACS provider's use of BLE

Join Us

Check Out Red Team Alliance Trainings and Certs

https://redteamalliance.com

Join the RFID Hacking Discord

https://discord.gg/Td9JkY8USu